

Expediente N.º: EXP202209677

RESOLUCIÓN DE PROCEDIMIENTO SANCIONADOR

Del procedimiento instruido por la Agencia Española de Protección de Datos y en base a los siguientes

ANTECEDENTES

PRIMERO: D. **A.A.A.** (en adelante, el denunciante) con fecha 29 de agosto de 2022 presentó denuncia ante la Agencia Española de Protección de Datos. La denuncia se dirige contra HM HOSPITALES 1989, S.A. con NIF A79325858 (en adelante, HM). Los motivos en que basa la misma son los siguientes:

El denunciante, (...), expone distintas deficiencias de seguridad relacionadas con el mantenimiento de un servicio de software desarrollado por la misma y utilizado por todos los centros hospitalarios de la mercantil denunciada.

Según expone el denunciante, "Doctoris" es un sistema de información hospitalaria completo e integral, compuesto de varias bases de datos que abarcan, desde los datos de los pacientes hasta sus experiencias clínicas, pasando por información de laboratorios o incluso las citas en los centros para las consultas.

Indica que no es un producto instalado en HM, sino un servicio cuya infraestructura se aloja en el Centro de Proceso de Datos de la empresa tecnológica que presta servicios a la denunciada, en el que se ubican los servidores principales del servicio, en especial los servidores de bases de datos y los sistemas de almacenamiento de datos y copias de seguridad.

Manifiesta que es esa compañía la que debe asegurar el funcionamiento 24/365 del sistema.

En la denuncia se detallan los siguientes supuestos incumplimientos de la normativa de protección de datos:

(...).

Junto a la denuncia se aportan sendos hilos de mensajes electrónicos remitidos a directivos de la tecnológica de HM en fechas 11/12/2019 y 17/5/2022.

El correo de 11 de diciembre de 2019 es remitido desde la dirección *****EMAIL.1** teniendo como destinatario (...), con el siguiente texto:

(...).

Este correo es contestado *****EMAIL.2** con el siguiente texto:

“(...)”

El segundo correo se envía el 17 de mayo de 2022 (...) y se remite desde la dirección *****EMAIL.1** a la dirección *****EMAIL.3** con el siguiente texto:

“...”.

SEGUNDO: Con fecha 19 de septiembre de 2022 la Directora de Agencia Española de Protección de Datos, ante las deficiencias de seguridad relacionadas con el mantenimiento de un servicio de software utilizado por todos los centros hospitalarios de la mercantil HM HOSPITALES 1989 S.A., dicta nota interior, instando a la Subdirección General de Inspección de Datos a que inicie de oficio actuaciones previas de investigación tendentes a acreditar estos hechos y su autoría.

TERCERO: La Subdirección General de Inspección de Datos procedió a la realización de actuaciones previas de investigación para el esclarecimiento de los hechos en cuestión, en virtud de las funciones asignadas a las autoridades de control en el artículo 57.1 y de los poderes otorgados en el artículo 58.1 del Reglamento (UE) 2016/679 (Reglamento General de Protección de Datos, en adelante RGPD), y de conformidad con lo establecido en el Título VII, Capítulo I, Sección segunda, de la LOPDGDD, teniendo conocimiento de los siguientes extremos:

Las actuaciones de investigación se han centrado en los siguientes puntos de control denunciados como supuestos incumplimientos a la normativa de protección de datos según documentación aportada por el denunciante:

(...).

En fecha 3 de abril de 2023 se realiza requerimiento de información al responsable de tratamiento HM marcado por la siguiente línea de investigación:

- Analizar el contrato de encargo de tratamiento entre este responsable y TRC INFORMÁTICA, S.L. (en adelante TRC INFORMÁTICA).
- Conocer los análisis de riesgos realizado por HM en relación con los tratamientos que afectan a TRC INFORMÁTICA, así como la acreditación de las medidas preventivas concluidas.
- Conocer las evaluaciones de impacto para las actividades de tratamiento que afectan a TRC INFORMÁTICA como encargado.
- En relación con el sistema de gestión hospitalaria denunciado, “DOCTORIS”, conocer:
 - Los tipos de datos personales que trata.
 - Los informes de las últimas auditorías realizadas.
 - Las medidas implantadas para garantizar la confidencialidad, la trazabilidad de los accesos, la confidencialidad de las personas que tienen acceso a los datos, la supresión o bloqueo de los datos y la disponibilidad ante pérdida o destrucción.
 - En relación con los sistemas de preproducción y desarrollo, obtener aclaración sobre si tratan datos reales o ficticios, y las medidas para

garantizar la confidencialidad de los usuarios que tienen acceso al sistema.

En fecha 26 de abril de 2023 se recibe respuesta al requerimiento anterior por parte de HM, de su análisis se extrae:

- Se aporta copia del contrato de encargo suscrito entre HM y TRC INFORMÁTICA, de su análisis se extrae:
 - Tiene fecha de firma 1 de enero de 2022 y contiene la firma de ambas partes que lo suscriben.
 - Sobre el objeto, naturaleza y finalidad del encargo: *“los servicios prestados son el desarrollo software de historia clínica electrónica y gestión de facturación, mantenimiento software y alojamiento de base de datos, requiriendo tratamiento de datos personales para estos servicios”.*
 - Se afirma: *“Que en cumplimiento del art. 28 del RGPD, el encargado ofrece suficientes garantías para implementar medidas adecuadas para proteger los derechos de los interesados y por tanto ambas partes han convenido suscribir el contrato.”*
 - Se detallan los tipos de datos afectados por el encargo, los tipos de interesados afectados y las obligaciones y derechos tanto de responsable como encargado.
 - Se detalla información sobre la notificación de violaciones de seguridad, la comunicación de datos a terceros por parte del encargado, las transferencias internacionales, sobre la posibilidad de subcontratación y sobre la atención a los derechos de los interesados.
 - Sobre el personal autorizado para realizar el tratamiento se especifica lo siguiente:
 - *El encargado garantiza que el personal autorizado para realizar el tratamiento se ha comprometido de forma expresa y por escrito a respetar la confidencialidad de los datos.*
 - *El encargado tomará medida para que este personal solo pueda tratar los datos siguiendo las instrucciones del responsable.*
 - *El encargado garantiza que el personal autorizado para el tratamiento ha recibido la formación necesaria para asegurar que no se pondrá en riesgo la protección de datos personales.*
 - Sobre las medidas de seguridad implantadas, se adjunta un anexo al contrato de encargo donde se afirma: *“El desarrollo del software DOCTORIS deberá contar con las siguientes medidas de seguridad en su diseño y por defecto:*

(...).
 - El contrato incluye información de contacto de ambos DPD e información sobre las obligaciones de supresión y devolución de los datos tras finalizar el servicio contratado.
- Se aporta el Registro de las Actividades de Tratamiento (RAT) de HM y se afirma que las actividades afectadas por tratamientos de datos en los que

interviene TRC INFORMATICA como encargado son dos, la actividad “Facturación” y la actividad “Historia Clínica Electrónica (HCE)”. En el RAT aportado se detalla la siguiente información para cada una de estas actividades: Finalidad, Legitimación, Categorías de Interesados, Criterios de Conservación, Origen de los Datos, Categorías de Datos, Categorías de Destinatarios y las Medidas de Seguridad.

- Para la actividad HCE se destaca la siguiente información contenida en el RAT:

- Datos: *DNI o NIF, nombre y apellidos de paciente, tarjeta sanitaria, identificador de usuario, imágenes, grabaciones, firma electrónica, firma manuscrita, características personales (personalidad o comportamiento), circunstancias sociales, académicas y profesionales, detalles de empleo.*
- Datos categorías especiales: *Origen étnico o racial, datos genéticos, salud, violencia de género, religión.*
- Plazos de Conservación de los datos: *“Mientras dura la atención sanitaria al paciente y con posterioridad, como mínimo, 5 años contados desde la fecha de alta de cada proceso asistencial, sin perjuicio de las particularidades autonómicas 26 que resulten de aplicación, o de la naturaleza de algunos documentos que integrarán la HCE, requiriendo su conservación indefinida (detallado en Protocolo de plazos de conservación de HM HOSPITALES, normativa sanitaria)”.*
- Medidas de seguridad:

(...).

- Para la actividad FACTURACIÓN se destaca la siguiente información contenida en el RAT:

- Datos: *DNI o NIF, nombre y apellidos de paciente y pagador, dirección postal o electrónica de facturación, identificador de Usuario.*
- Datos categorías especiales: *Datos de salud relativos a la prestación de la asistencia sanitaria objeto de facturación (HCE).*
- Plazo de conservación: *“Los datos se mantendrán durante el tiempo que es necesario para cumplir con la finalidad para la que se recabaron y posteriormente para determinar las posibles responsabilidades que se pudieran derivar de dicha finalidad y del tratamiento de los datos. De conformidad con el Art. 25 de la Ley 10/2010, de 28 de abril, de prevención del blanqueo de capitales y de la financiación del terrorismo., se conservarán durante 10 años desde la terminación de la relación de negocios o la ejecución de la operación.”*
- Medidas de seguridad:

(...).

- En respuesta a la solicitud para que aporten los análisis de riesgos de las actividades de tratamiento en las que interviene el encargado TRC INFORMATICA, aportan únicamente un documento de análisis de riesgos para los tratamientos de “fiscal y contable” y afirman que estos incluyen el tratamiento de la actividad “Facturación”, no se aporta análisis de riesgos para la actividad de tratamiento HCE. De este documento se extrae:

- Se realiza la siguiente afirmación de fechas:
 - *“Fecha inicio del tratamiento: ya iniciado con anterioridad, pero se actualiza el 31 de Marzo de 2023 con la última implantación de DOCTORIS.*
 - *Fecha de redacción del informe: 31/03/2023”*
- En el análisis se adjunta la copia de un *informe de cumplimiento normativo realizado para la actividad de tratamiento Facturación*, del que se destaca la siguiente afirmación realizada en el apartado conclusiones del informe:

(...).
- Se analizan los factores de riesgo:

(...).
- Se concluye una evaluación de riesgo inherente MEDIO y riesgo residual MEDIO.
- Se aporta un plan de acción que incluye:

(...).
- En respuesta a la solicitud para que aporten la Evaluación de Impacto (EIPD) de los tratamientos en los que interviene el encargado TRC INFORMÁTICA, se aporta únicamente un documento con la EIPD para la actividad de tratamiento HCE *“Historia Clínica Electrónica”*, no aportándose la EIPD para la actividad de tratamiento *“Facturación”*. Del análisis de este documento se extrae:
 - Se realiza la siguiente afirmación de fechas:
 - *“Fecha de inicio del tratamiento: 31-03-2023 (primera fase implantación finalizada de DOCTORIS, aunque el tratamiento ya se había iniciado a través de HOSMA con anterioridad)*
 - *Fecha de realización del informe EIPD: 15-03-2023. Versión: 3.”*
 - Se afirma: *“Tratamiento a gran escala de categorías especiales de datos personales. Tratamiento que entrañe un alto riesgo para los derechos y libertades de las personas físicas”.*
 - En esta EIPD se adjunta la copia de un informe interno de cumplimiento normativo realizado para la actividad de tratamiento HCE, conteniendo las siguientes afirmaciones en el apartado de conclusiones:

(...).
 - Se realiza una descripción del tratamiento y del ciclo de vida de los datos, analizándose cada una de las siguientes operaciones de tratamiento: captura, registro, uso, comunicación y supresión. Para cada operación se especifica el tipo de datos que trata, el origen de los datos, las medidas de seguridad implantadas y las tecnologías involucradas.
 - Se identifican y evalúan los siguientes factores de riesgos:

(...).
 - Se aportan los siguientes controles para reducir el riesgo:
 - *Establecer medidas de concienciación y formación del personal implicado en las operaciones de tratamiento de datos personales.*
 - *Establecimiento de medios técnicos para la detección automática de brechas de datos personales.*
 - Se concluye con riesgo inherente MEDIO y residual total MEDIO.

- Se afirma que los siguientes riesgos *son transferidos* a TRC INFORMÁTICA SL:
(...).
- Se concluye con un plan de acción que incluye los siguientes controles:
 - *Controles para reducir el riesgo por incumplimiento normativo:*
(...).
 - *Controles para reducir los riesgos para los derechos y libertades de los interesados:*
(...).
 - *Controles destinados a transferir el riesgo:*
(...).
- Se analiza la necesidad y proporcionalidad del tratamiento llegándose a la siguiente conclusión: “La evaluación de la necesidad y proporcionalidad del tratamiento respecto a su finalidad es adecuada y puede procederse a la gestión de riesgos”.
- Se aportan las siguientes conclusiones de la EIPD: (...).
- En respuesta a la solicitud para que aporten la última auditoría específica realizada para el sistema de información hospitalaria DOCTORIS se contesta: “HM HOSPITALES no ha realizado auditoría al sistema de información DOCTORIS pues su implantación en el grupo hospitalario es reciente”.
- En respuesta a la solicitud para aporten las medidas técnicas implantadas para garantizar la confidencialidad de los tratamientos, contestan:
(...).
- En respuesta a la solicitud para que acrediten las medidas para garantizar la trazabilidad de los accesos:
(...).
- En respuesta a la solicitud para que acrediten las medidas para garantizar la disponibilidad ante la posible pérdida, destrucción o daño accidental:
(...).
- En respuesta a la solicitud para que acrediten las medidas para garantizar la supresión o bloqueo una vez finalizado el plazo de conservación:
(...). No obstante, existen pruebas de que DOCTORIS no es un nuevo software, sino que muy posiblemente se trata de la evolución de uno ya existente (HOSMA) y que ambos dan soporte a la misma actividad de tratamiento HCE (Historia Clínica Electrónica).
- En relación con los sistemas de preproducción o desarrollo de DOCTORIS se afirma:
 - Que las pruebas relativas a la implantación o modificación de DOCTORIS no se realizarán con datos reales.
 - Que los perfiles de acceso a datos de HM se hacen por desarrolladores autorizados. Se aporta un listado con nombre y apellidos de estas personas autorizadas y se afirma que existen “desarrolladores varios” que acceden a Preproducción, pero con datos desnormalizados.
- Se aporta documento acreditando la certificación ISO 27001:2017 por parte del encargado de tratamiento, TRC INFORMÁTICA SL.

En relación con el tratamiento de la Historia Clínica Electrónica (HCE) por parte de HM HOSPITALES y el encargado TRC INFORMÁTICA, se diligencian en el transcurso de esta investigación las siguientes evidencias de noticias publicadas en portales

relevantes de internet sobre la implantación del sistema de información que da soporte a la Historia Clínica Electrónica:

- Noticia publicada por el portal web de TRC INFORMÁTICA sobre el proyecto de desarrollo del aplicativo de Gestión Hospitalaria Doctoris para el cliente HM HOSPITALES, constando como fecha del proyecto desde el año 2010 hasta la actualidad.
- Noticia publicada en varios portales web de salud en el año 2011 con el titular “HM Hospitales ha implantado la historia clínica electrónica en todos sus centros” donde se afirma que HM ha terminado de implantar la Historia Clínica Electrónica en todos sus centros bajo un único sistema conocido como HOSMA DR, y que se pretendía avanzar en el desarrollo de nuevas aplicaciones que mejoren su funcionamiento.
- Noticia publicada en portal web *computing.es* en el año 2013 sobre la revolución tecnológica en HM Hospitales y que anuncia la nueva implantación de HOSMA 2.0 como evolución de la Historia Clínica Electrónica realizada por HM de la mano con TRC INFORMÁTICA.

En fecha 30 de mayo de 2023 se decide realizar requerimiento de información al denunciante, marcado por la siguiente línea de investigación:

- Contrastar la información aportada por HM.
- Solicitar la aportación de pruebas en contrario en relación (...).

En fecha 7 de junio de 2023 se recibe respuesta a dicho requerimiento anterior, de la respuesta recibida se pueden extraer las siguientes consideraciones:

- Afirma que “HOSMA 1.0, HOSMA 2.0, y DOCTORIS no son en absoluto tres sistemas diferentes, sino evoluciones de los frontends del mismo sistema, con diferentes tecnologías según el momento y con funcionalidades tanto diferentes como solapadas.”
- En relación con las auditorías, afirma que desde hace años la empresa KPMG hace auditorías al sistema completo (antes HOSMA y ahora DOCTORIS) pero que no existe una auditoría exclusiva para el sistema DOCTORIS, ya que este es solo una evolución del frontend del sistema completo de información hospitalaria.
- (...).

En fecha 31 de mayo de 2023 se decide realizar nuevo requerimiento de información a HM marcado por la siguiente línea de investigación:

- Que se acredite la existencia de un protocolo para gestionar las brechas de seguridad, tal y como se afirma en respuesta al primer requerimiento.
- Que se acredite la existencia de una Evaluación de Impacto de fecha anterior a la aportada (15 de marzo de 2023) ya que el inicio del tratamiento es bastante anterior a esta fecha.
- Solicitar copia del último informe de auditoría realizado por la empresa KPMG, según se incluía en el plan de acción de la Evaluación de Impacto que nos aportaban.
- (...).
- Que se acredite que los sistemas de preproducción trataban datos ficticios y no reales.

En fecha 12 de junio de 2023 se recibe respuesta al requerimiento anterior, de su análisis se extrae:

- El escrito lo firma el Delegado de Protección de Datos de HM (D. **B.B.B.**).
- Se adjunta y acredita la existencia de protocolo de gestión de brechas de seguridad, documento con fecha de creación diciembre de 2020 y que recoge aspectos para identificar, clasificar y valorar la dimensión y alcance de los posibles incidentes de seguridad que pueda sufrir la organización, así como establecer un plan de actuación interno de prevención, mitigación y de cumplimiento.
- A nuestra solicitud para que aporten la Evaluación de Impacto (EIPD) realizada en momentos previos al inicio de tratamiento, se aporta un nuevo documento de EIPD realizada para la actividad HCE, de su análisis se extrae:
 - El documento no está firmado y tiene fecha de creación de 16 de diciembre de 2020.
 - Incluye el análisis de la necesidad de llevar a cabo la EIPD.
 - Se afirma que se ha realizado un análisis de riesgo inherente y que se aporta en documento adicional anexo junto al plan de acción, no obstante, no se localizan estos documentos adicionales.
 - Se afirma que *“Una vez evaluados los potenciales riesgos se concluye que el tratamiento no supone una amenaza para los derechos y libertades de los pacientes”*.
 - En la EIPD no se realiza análisis de necesidad, idoneidad y proporcionalidad del tratamiento.
 - En la EIPD no se lleva a cabo una descripción sistemática del tratamiento.
- En respuesta a nuestra solicitud para que confirmen y acrediten la realización de auditoría al sistema de información clínica por parte de la empresa KPMG, se aporta un documento que tiene como título *“Informe legal comprensivo de los riesgos e impacto jurídico asociado a un ciberincidente, incluyendo recomendaciones y buenas prácticas”*, con fecha de creación 12 de septiembre de 2022.
- En relación con nuestra solicitud para que acrediten el (...).
- En relación con la acreditación del uso de datos ficticios por los sistemas de preproducción afirman: *“Se informa que las pruebas realizadas tienen lugar en un entorno de PRE-PRODUCCIÓN en el que se simulan situaciones con bases de datos ficticias generadas a través del empleo de técnicas como simulación de ruido y perturbación de datos.”*. Se aporta captura de pantalla de DOCTORIS con una muestra muy reducida de 12 registros de supuestos pacientes ficticios.

En fecha 31 de mayo de 2023 se decide realizar nuevo requerimiento de información al encargado TRC INFORMÁTICA marcado por la siguiente línea de investigación:

- Solicitar copia del informe de la última auditoría realizada por KPMG.
- Solicitar el registro de actividades de tratamiento como encargado.
- Solicitar acreditación de las medidas implantadas para garantizar la trazabilidad de los accesos a las historias clínicas.
- Solicitar la acreditación de los procedimientos establecidos para la supresión y bloqueo de los datos.

En fecha 13 de junio de 2023 se recibe escrito por parte de TRC INFORMÁTICA solicitando ampliación de plazo que se responde favorablemente en fecha 14 de junio de 2023 otorgando plazo adicional de 5 días.

En fecha 3 de julio de 2023 se recibe respuesta al requerimiento anterior por parte de TRC INFORMÁTICA, de su análisis se extrae:

- En respuesta a nuestra solicitud para que aporten copia de los informes de auditoría realizados por la empresa KPMG a los sistemas de gestión de información hospitalaria afirman: *“KPMG es la empresa auditora de nuestro cliente HM HOSPITALES 1989 S.A y no es la empresa auditora TRC INFORMÁTICA, en consecuencia, no podemos aportar las copias de los informes requeridos”*.
- En relación con el listado y acreditación de las medidas implantadas para garantizar la trazabilidad de los accesos a las Historias Clínicas Electrónicas se acredita las mismas medidas que previamente se habían acreditado en la respuesta de HM HOSPITALES, en concreto:
 - Se acredita el registro de los intentos de acceso al sistema Doctoris.
 - Se acredita el registro de los distintos módulos del sistema visitados por el usuario (opciones del programa).
 - Se acredita el registro de consultas lanzadas a la base de datos de forma directa sin hacer uso de DOCTORIS.
 - Se acredita el registro de cambios realizados en la tabla pacientes.
- (...).
- En relación con nuestra solicitud para que acrediten las medidas para el bloqueo o supresión, afirman: (...).
- Afirman (aunque no acreditan) que TRC INFORMÁTICA se encuentra certificada por la empresa OCA GLOBAL en la norma ISO/IEC 15504, ISO/IEC 33001. Anteriormente ya se había acreditado la certificación en la norma ISO/IEC 27001.

En fecha 14 de junio de 2023 se decide realizar nuevo requerimiento de información al responsable de tratamiento HM solicitando la aclaración de algunos aspectos de su anterior respuesta, en concreto se solicita:

- Que confirme la relación existente entre los sistemas DOCTORIS, HOSMA1 y HOSMA 2, con la finalidad de aclarar si se tratan de sistemas que dan soporte a la misma actividad de tratamiento HCE.
- Teniendo en cuenta que el contrato de encargo aportado entre TRC INFORMATICA y HM tiene fecha de 1 enero de 2022, y de las evidencias obtenidas de internet sobre el inicio de este proyecto de desarrollo con fecha bastante anterior, se solicita que confirme (y acredite en su caso) la existencia de contrato de encargo con fecha anterior al aportado.
- Que confirme y aporte el listado de posibles contratos de servicios con el sector público vinculados con el sistema de información hospitalaria.
- Que confirmen si existieron auditorías específicas para algunos de los sistemas HOSMA o DOCTORIS en los tres últimos años con objeto de verificar las medidas implantadas y evaluar su eficacia.

En fecha 21 de junio de 2023 se recibe escrito por parte de HM aportando respuesta a los dos primeros puntos del requerimiento de información y solicitando ampliación de plazo para contestar a los puntos restantes. Se contesta favorablemente otorgando plazo adicional de 5 días. Con respecto a los dos puntos contestados se extrae:

- En respuesta a nuestra solicitud para que confirmen si existía un contrato de encargo firmado con fecha anterior al 1 de enero de 2022, aportan un nuevo documento con un nuevo contrato de encargo firmado a fecha 1 de junio de 2019 con las siguientes características:
 - Lo suscriben por un lado PROFESIONALES DE LA MEDICINA Y LA EMPRESA S.A con CIF A79272118 y de otra parte GRUPO TRC compuesto por las empresas TRC INFORMÁTICA SL (B7951315) y GRUPALIA INTERNET SA (A47436019).
 - Se afirma que el responsable ha contratado los servicios del encargado *cuya finalidad se detalla en el manifestando segundo*, no obstante, no se aportan estos anexos (manifestando) por lo que se desconoce el objeto del encargo y no se puede acreditar que el encargo esté relacionado con el sistema de historias clínicas electrónicas de pacientes.
 - El contrato especifica la siguiente tipología de datos afectados: datos básicos, de especial protección (convicciones religiosas y filosóficas, condenas y delitos penales, origen étnico o racial, vida u orientación sexual, violencia de género), datos que identifican características personales, académicos y profesionales, detalles de empleo, económicos, financieros y de seguros, infracciones administrativas, datos biométricos, sanitarios y genéticos.

En fecha 28 de junio de 2023 se recibe respuesta al requerimiento anterior por parte de HM, de su análisis se extrae:

- Se confirma que tanto "HOSMA 1.0" Y "HOSMA 2.0" son versiones anteriores a DOCTORIS, Sistema de información hospitalario utilizado por HM para la gestión de la historia clínica electrónica (HCE).
- Se realiza la siguiente afirmación: *"En relación con la realización de auditorías sobre cualquiera de las versiones de Doctoris en los últimos tres años esta parte informa que no ha tenido lugar ninguna. Debido a la situación de la pandemia de COVID-19, HM Hospitales se ha visto obligado a redirigir sus recursos y prioridades principalmente hacia la asistencia sanitaria y la seguridad de los pacientes y del personal, una vez superada la situación de emergencia sanitaria el Comité de Privacidad HM HOSPITALES aprobó en abril de 2023 la realización de auditorías en distintos centros para verificar el nivel de cumplimiento en relación con la normativa vigente de protección de todos los sistemas de información en el segundo semestre de este año".*
- Se aporta el listado de las licitaciones con el sector público obtenidas por HM en los últimos dos años, destacando entre otras las siguientes:
 - Con SESCAM, en el año 2022, sobre "Asistencia sanitaria a pacientes".
 - Con el Servicio Madrileño de Salud, en el año 2022, sobre "Pruebas diagnósticas".
 - Con el INGESA, en 2022 y 2023, sobre "Reconocimientos médicos preventivos para empleados públicos"
- Afirman que HM se encuentra actualmente en proceso de implantación del ENS, proyecto que se inicia con su primera fase en abril de 2023 y que continuará con la siguiente planificación:
 - Julio de 2023 se realizará la fase de "Inventario de activos, análisis de riesgos y selección de controles".

- Agosto y Septiembre de 2023 se realizará la elaboración o ampliación de la documentación del alcance definido.
- Octubre- Diciembre de 2023 fases de implantación del sistema, auditoría interna y proceso de certificación.

CUARTO: Con fecha 29 de agosto de 2023, la Directora de la Agencia Española de Protección de Datos acordó iniciar procedimiento sancionador a la parte reclamada, con arreglo a lo dispuesto en los artículos 63 y 64 de la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en adelante, LPACAP), por la presunta infracción del Artículo 32 del RGPD, tipificada en el Artículo 83.4 del RGPD.

QUINTO: Notificado el citado acuerdo de inicio conforme a las normas establecidas en la LPACAP, la parte reclamada presentó escrito solicitando ampliación del plazo concedido para formular alegaciones, así como copia del expediente.

Con fecha 13 de septiembre de 2023 se acordó la ampliación concedida, debiendo computarse a partir del día siguiente a aquel en que se recepcione la copia del expediente solicitado.

La copia del expediente se notificó en fecha 2 de octubre de 2023.

Si bien, HM presenta alegaciones en fecha 14 de septiembre de 2023, solicitando se admitan y se tengan por realizadas, a fin de ser tenidas en cuenta a la hora de emitir la resolución al procedimiento referenciado, y en su virtud proceda a anular o minorar la sanción propuesta por no concurrir los requisitos para su imposición.

En sus alegaciones, en síntesis, la parte reclamada aduce:

1.- En su primera alegación, HM hace referencia a la trazabilidad afirmando que acreditó las medidas técnicas y organizativas de seguridad implantadas para garantizar la trazabilidad de los accesos a los datos personales por parte de los usuarios autorizados en su primer escrito de contestación al requerimiento de información por parte de la AEPD, de fecha 27 de abril de 2023. No obstante, a continuación, reconoce que, en la evaluación de impacto aportada en la misma fecha y realizada el 15 de marzo de 2023, se detectó que DOCTORIS no permitía registrar a qué HCE concreta había accedido cada usuario salvo que hubiera modificado los registros. Asimismo, afirman haber subsanado este problema aportando pantallazos de las pruebas que han realizado para acreditarlo.

2.- En su segunda alegación, aluden a la existencia de informes internos del responsable de HM sobre el cumplimiento normativo de estas actividades (Anexos n.º 1 y n.º 2 adjuntos a las alegaciones) destacando una serie de puntos que se recogen en las conclusiones de dichos informes del año 2023 y que se detallan a continuación:

- Se detecta que los perfiles no están bien implantados (enfermería, investigadores): a este respecto aclaran haber detectado un riesgo que consideran resuelto en la actualidad y que se origina por la concesión de un perfil de investigadores errónea; puesto que, algunos de los sujetos a los que se había concedido no eran investigadores sino personal de enfermería. Detalla

que, para solucionarlo, adoptan en 2023 una serie de medidas como la limitación del número de usuarios que pueden administrar, modificar y crear perfiles en DOCTORIS.

- Se detecta que DOCTORIS permite la trazabilidad de accesos y de modificaciones, pero no permite conocer quien consulta los datos de HCE. A este respecto, se limitan a señalar que ya ha sido explicado en su primera alegación.
- Conservación LOGS acceso, además se conserva quién realiza la actividad, cuándo la realiza y sobre qué información, sea cual sea el usuario. Revisión de los mismos de manera mensual: proceden a detallar los plazos durante los cuales conservan los registros y los motivos por lo que lo hacen, destacando que una vez determinados los tiempos, se ha programado el borrado automático de los mismos que con anterioridad se realizaba de forma manual.

3.- En su tercera alegación, la parte reclamada alude a las auditorías para confirmar que no se ha realizado ninguna auditoría específica al software DOCTORIS en los tres últimos años y lo justifican en el constante cambio/mejora al que está sometido el programa. Añade, que lo que sí se ha hecho en este período de tiempo, es llevar a cabo dos evaluaciones de impacto que afirma, fueron aportadas a esta Agencia con anterioridad.

Seguidamente, pasa a la realización de auditorías como medidas de seguridad de la actividad HCE reflejada en el Registro de Actividades de tratamiento, para sostener que sí que se han realizado. En particular, indica que se han llevado a cabo auditorías de cumplimiento normativo vinculado al tratamiento de HCE y que DOCTORIS ha sido objeto de verificación mediante un procedimiento de homologación de sistema de receta electrónica en el marco del cual se certifica que el sistema dispone de un nivel de cumplimiento adecuado.

4.- A continuación, alude al cifrado de los datos para afirmar que la base de datos de historias clínicas de pacientes DOCTORIS ha contado siempre con un sistema de cifrado de datos personales que ha sido mejorado en varias ocasiones. Continúa explicando que este sistema tenía, por defecto, un cifrado automático y que éste se ha mejorado. Prosigue explicando la manera en la que se han implementado esas mejoras y concluye diciendo que actualmente se ha finalizado el proceso de implantación del cifrado con tecnología TDE de SQL Server, incluyendo en su escrito una serie de pantallazos del sistema.

5.- En su quinta alegación la parte reclamada alude nuevamente a conclusiones recogidas en sus informes internos. En particular, analiza los siguientes extremos:

- Los datos personales se mantienen durante más tiempo del necesario respecto de los fines, sin ser estos fines de archivo en interés público, investigación científica, históricos o estadísticos.
Comienza su explicación reconociendo que fue en la EIPD realizada en marzo de 2023 donde se detectó el riesgo de mantener los datos más tiempo del necesario de acuerdo con el fin del tratamiento. Ahora bien, argumenta que, debido a la naturaleza y extensión de los centros con los que cuenta, repartidos por todo el territorio nacional, se han de tener en cuenta disposiciones normativas diversas, variando los tiempos según los criterios que deban

aplicarse a cada centro de referencia citando diversos ejemplos autonómicos en los que se establecen periodos de conservación distintos para finalmente decir que han fijado un criterio unívoco para todos ellos.

- El proceso tiene lugar de forma manual y se requiere automatizar procesos con la finalidad de cumplir con el Protocolo de plazos de conservación de HM HOSPITALES: consideran que es necesaria la intervención de un profesional sanitario para determinar si procede o no la eliminación de los datos de la historia clínica, refiriéndose a sus Instrucciones técnicas y de mejora de los registros en Dharma (Anexo nº 3) a modo de aclaración.
- Se ha detectado que DOCTORIS no permite supresión/bloqueo automático y debe realizarse de forma manual. Doctoris no dispone de un proceso automatizado de bloqueo y supresión de datos personales, sino que debe realizarse manual por lo que existe riesgo de incumplimiento en lo que respecta al principio de limitación de plazo de conservación: a este respecto, incide nuevamente en que se ha implementado un mecanismo que permite bloquear los datos de salud en DOCTORIS así como el borrado automático de los mismos una vez que haya transcurrido el plazo de tiempo establecido al efecto.

6.- Finalizan su exposición refiriéndose a la aplicación en el procedimiento del agravante de Intencionalidad o negligencia por entender que éste no resulta de aplicación. Fundamentan la inaplicabilidad del mismo en los siguientes aspectos:

- a) Las investigaciones de la AEPD tienen su origen en la denuncia de un antiguo empleado, no en la concurrencia de un incidente de seguridad o la reclamación de un paciente;
- b) Son conscientes de la importancia del tratamiento de datos de salud a gran escala y prueba de ello es la realización de dos evaluaciones de impacto por su parte, las referidas con anterioridad de diciembre de 2020 y marzo de 2023, Cuyo objeto es el de evaluar y minimizar los posibles riesgos que puedan afectar a la privacidad y seguridad de los datos de los pacientes;
- c) Consideran haber demostrado que el sistema de gestión de historias clínicas cuenta con medidas de seguridad y con protocolos de seguridad informática para evitar accesos no autorizados. A lo anterior añaden haber realizado acciones de concienciación y formación de su personal para reforzar la cultura de privacidad y el adecuado tratamiento de información sensible;
- d) Destaca el hecho de que se encuentran actualmente en proceso de implantación del Esquema Nacional de Seguridad (ENS)
- e) Por último, aluden a su plena colaboración con la administración durante toda la investigación.

Junto con dichas alegaciones HM adjuntó la siguiente documentación:

- ANEXO N.º 1: Informe de análisis de necesidad de EIDP del tratamiento.
- ANEXO N.º 2: Informe final de valoración del cumplimiento del procedimiento de homologación de sistema de receta médica privada electrónica.
- ANEXO N.º 3: Instrucciones técnicas y de mejora de los registros en DHARMA.

SEXTO: Con fecha 30 de septiembre de 2023, se recibe en esta Agencia Española de Protección de Datos una ampliación de la denuncia presentada por D. **A.A.A.** en fecha 29 de agosto de 2022.

En dicha ampliación de la denuncia se hace constar que (...).

SÉPTIMO: Con fecha 8 de abril de 2024 se notificó la apertura del periodo probatorio y se requirió a HM la siguiente documentación e información:

Informe del resultado de las auditorías llevadas a cabo en los distintos centros para verificar el nivel de cumplimiento en relación con la normativa vigente de protección de todos los sistemas de información en el segundo semestre de 2023, de conformidad con el PLAN SEMESTRAL DE AUDITORÍAS DEL SISTEMA DE GESTIÓN DE PRIVACIDAD (SGP).

OCTAVO: Notificada la apertura del periodo probatorio, con fecha 26 de abril de 2024, la entidad presentó escrito en el que afirma haber llevado a cabo la auditoría de sus centros ubicados en Málaga y haber pospuesto para el segundo semestre de este año la del centro de Arganda conforme a su plan de semestral de auditorías, sin hacer referencia al resto de sus centros. Asimismo, adjunta la siguiente documentación:

ANEXO Nº1: Resultados de la Auditoría llevada a cabo en los centros de Málaga.

ANEXO Nº2: Registro del Delegado de Protección de Datos ante la Agencia Española de Protección de Datos, de Desarrollos Asistenciales Sur, S.L.

ANEXO Nº3: Registro como Delegado de Protección de Datos de HM HOSPITALES 1989 S.A.

NOVENO: Con fecha 11 de junio de 2024 se formuló propuesta de resolución, proponiendo se sancione a HM HOSPITALES 1989, S.A., con NIF A79325858, por una infracción del Artículo 32 del RGPD, tipificada en el Artículo 83.4 del RGPD, con una multa 200.000 € (DOSCIENTOS MIL EUROS).

DÉCIMO: Notificada la propuesta de resolución conforme a las normas establecidas en la LPACAP, la parte reclamada presentó escrito alegaciones en fecha 26 de junio de 2024.

En sus alegaciones, en síntesis, la parte reclamada manifiesta:

1.- En su primera alegación, HM hace referencia al cifrado de datos e indica que el instructor del expediente da a entender que HM Hospitales considera que el cifrado en cabina no es suficiente y por eso planificaron el cifrado por software DES de SQL, procediendo a indicar los aspectos cruciales en su compromiso con la seguridad de datos así como en el equilibrio de la prestación de asistencia sanitaria y la garantía en la disponibilidad de los datos. Consideran que el cifrado previamente utilizado por HM HOSPITALES ya proporcionaba un nivel de seguridad que superaba el mínimo procediendo a describir los estándares de cifrado que usaban, el hecho de que el cifrado lo realizaban a nivel de firmware y las ventajas de las unidades de autocifrado utilizadas

2.- En su segunda alegación, HM se refiere a los informes de las distintas auditorías: (...).

En este último informe se hace referencia a las áreas de mejora de IT del software DOCTORIS.

3.- En su tercera alegación, HM alega la buena diligencia en la elección del encargado del tratamiento, en garantía de la aplicación de las medidas técnicas y organizativas apropiadas, dejando constancia de los certificados con los que cuenta dicho encargado del tratamiento.

4.- En la cuarta alegación, HM hace referencia a cada uno de los extremos en los que considera que este Organismo ha basado la falta de medidas de técnicas y organizativas adecuadas al tratamiento:

- El sistema de cifrado.
- La utilización de datos ficticios en entornos de pruebas de preproducción y desarrollo.
- Inexistencia de trazabilidad de los accesos al sistema de gestión hospitalaria por partes de los usuarios que accedan a las historias clínicas.
- La realización de auditorías.
- Los perfiles de los usuarios.

Concluye que ha demostrado el grado de cumplimiento (en todo, o en parte) de cada uno de esos aspectos con la documentación aportada durante el procedimiento.

5.- En la quinta alegación, HM hace referencia al principio de proporcionalidad, establecido en el artículo 29 de la Ley 40/2015 de Régimen del Sector Pública en la imposición de sanciones por parte de las Administraciones, y concretamente, considera los siguientes criterios:

- Grado de culpabilidad o intencionalidad.
- Continuidad o persistencia en la conducta infractora.
- Naturaleza de los perjuicios causados.
- Reincidencia.

Todo lo anterior, le lleva a concluir que procede anular el procedimiento o, en su defecto, minorar la cuantía de la sanción propuesta por entender que no concurren los requisitos para su imposición.

Junto con dichas alegaciones HM adjuntó la siguiente documentación:

ANEXO N.º 1: Documento sobre características técnicas que garantiza el proveedor Fujitsu así como certificado de TRC INFORMÁTICA relativo al cifrado.

ANEXO N.º 2: Informe de Auditoría de KPMG.

ANEXO N.º 3: Relación de certificaciones concedidas a TRC INFORMÁTICA.

De las actuaciones practicadas en el presente procedimiento y de la documentación obrante en el expediente, han quedado acreditados los siguientes:

HECHOS PROBADOS

PRIMERO: Ha quedado acreditado, tal y como consta en el expediente y en su propia página web *****URL.1**, que HM HOSPITALES 1989, S.A. con NIF A79325858 y domicilio en Plaza Conde Valle De Suchil, 2 - 28015 Madrid, es un grupo hospitalario privado que presta sus servicios a nivel nacional disponiendo de 49 centros distribuidos en el territorio español, en particular en la Comunidad de Madrid, Galicia, Castilla y León, Castilla-La Mancha, Cataluña y Andalucía.

SEGUNDO: Consta en el expediente, mediante escrito aportado por Don **A.A.A.** en fecha 6 de junio de 2023, el siguiente enlace *****URL.2**, que permite acceder a la publicación del registro como marca de la aplicación “*Doctoris*” en fecha 16 de noviembre de 2017, solicitada por TRC INFORMÁTICA S.L.

TERCERO: Consta probado en el expediente, mediante escrito presentado por Don **A.A.A.** en el marco de las actuaciones de investigación realizadas, que “*Doctoris*” es el software de gestión hospitalaria utilizado por HM HOSPITALES 1989, S.A.

Consta en el expediente que la aplicación informática “*Doctoris*” es una evolución de Hosma (Hosma 1.0 y Hosma 2.0).

Hosma 1.0 se implantó aproximadamente en 2008.

La entrada en funcionamiento de Hosma 2.0 fue aproximadamente 2013.

Hosma 3.0 no existió y Hosma 4.0 es “*Doctoris*”

CUARTO: Consta acreditado en el expediente, concretamente, en el informe de cumplimiento normativo anexionado al Análisis de Riesgos relativo a la protección de datos de fecha 31 de marzo de 2023, que el tratamiento de datos que realiza HM HOSPITALES 1089, S.A. recae sobre las siguientes categorías de datos:

- *“Datos básicos: Datos personales que no correspondan a categorías especiales de datos ni a condenas y delitos penales, por ejemplo: nombre, dirección, e-mail, teléfono, edad, sexo, firma, imagen, aficiones, patrimonio, datos bancarios, información académica, profesional, social, comercial, financiera, etc.*
- *Categorías especiales de datos: Datos relativos al origen étnico o racial, opiniones políticas, convicciones religiosas o filosóficas, afiliación sindical, datos genéticos o biométricos que permitan la identificación unívoca de una persona, datos relativos a la salud o a la vida y orientación sexuales.”.*

QUINTO: Consta en el expediente que dicho tratamiento, tal y como consta en el Informe de análisis de necesidad de Evaluación de Impacto de Datos Personales, aportado HM HOSPITALES en fecha 14 de septiembre de 2023, es a gran escala.

Tratamientos que impliquen el uso de datos a gran escala.	SI	Atendiendo a las recomendaciones del Grupo de Trabajo del 29, podemos considerar que se da tratamiento a gran escala por el volumen de datos, la variedad de elementos de datos que son objeto de tratamiento y la duración o permanencia de la
---	----	---



	actividad de tratamiento de datos.
--	------------------------------------

SEXTO: Consta en el expediente, contrato de encargado del tratamiento aportado por HM HOSPITALES 1989, S.A. en fecha 26 de abril de 2023 y firmado entre este, como responsable del tratamiento, y TRC INFORMÁTICA, S.L., como encargado del tratamiento, en fecha 1 de enero de 2022, con la siguiente información:

ANEXO Nº 1.- MEDIDAS DE SEGURIDAD

El desarrollo del software DOCTORIS deberá contar con las siguientes medidas de seguridad técnicas y organizativas en su diseño y por defecto:

- Disponer de diferentes perfiles de acceso configurables. Los accesos a datos e informaciones deben quedar regulados por este control de accesos de manera que cada usuario solo acceda a aquellos recursos que necesite para el desarrollo de las tareas encomendadas, según los criterios de los responsables. También debe permitir disponer de un listado actualizado de usuarios.
- Los controles de acceso se regirán por un sistema de identificación y autenticación que garantice la correcta identificación y autenticación de los usuarios de forma unívoca y personalizada. Mediante contraseñas seguras tanto en longitud como en su complejidad y que permitan su cambio al menos una vez al año de forma obligatoria. Las contraseñas se almacenarán siempre de manera cifrada en el sistema.
- Se debe establecer una política de eliminación de cuentas inactivas y bloqueo de sus datos.
- Será conveniente establecer un límite de intentos de accesos no autorizados a los sistemas que requieran identificación y autenticación.
- Deberá establecerse un procedimiento de copias de seguridad que garantice la disponibilidad de los datos ante una contingencia. Este procedimiento deberá contener el protocolo de recuperación de datos si llegado el caso hay que recuperarlos de una copia de seguridad. Las copias en la nube deberán estar deslocalizadas frente al dato original.
- El sistema debe garantizar el archivo de datos e informaciones en base a los criterios que establezcan los responsables de manera que se permita almacenarlos una vez concluida la relación con el interesado en base a los plazos legales de conservación o al cumplimiento de la finalidad establecida.

SÉPTIMO: Consta probado en el expediente, mediante escrito presentado por HM HOSPITALES en fecha 28 de junio de 2023, las referencias a los siguientes contratos firmados entre HM HOSPITALES y el sector público para la prestación de asistencia sanitaria, desde el año 2022:

OCTAVO: Consta en el expediente Informe de cumplimiento normativo, correspondiente al Análisis de Riesgos relativo a la Protección de Datos realizado en fecha 31 de marzo de 2023 y bajo la coordinación de Doña **C.C.C.**.

El objeto del informe es analizar la normativa que afecta al tratamiento de datos personales mediante su aplicación a cada fichero para demostrar su cumplimiento, informando de:

- Las medidas implementadas en la organización para la protección de datos personales.
- Las deficiencias encontradas y las medidas correctoras a implementar.

En el Tratamiento de Facturación, Registro de las obligaciones fiscales y contables sujetas a la actividad económica, se hace constar la siguiente información:

NOVENO: Consta en el expediente las siguientes evaluaciones de impacto relativas a la protección de datos:

EVALUACIÓN DE IMPACTO RELATIVA A LA PROTECCIÓN DE DATOS HISTORIA CLÍNICA ELECTRÓNICA de fecha 16 de diciembre de 2020.

EVALUACIÓN DE IMPACTO RELATIVA A LA PROTECCIÓN DE DATOS de fecha 15 de marzo de 2023.

DÉCIMO: Consta en el expediente Informe de Evaluación de Impacto relativa a la Protección de Datos HM HOSPITALES 1989, S.A., de fecha de realización el 15 de marzo de 2023 y bajo la responsabilidad de Don **D.D.D.**, delegado de protección de datos.

A dicha Evaluación de Impacto se anexa Informe de cumplimiento normativo, en el que consta literalmente:

UNDÉCIMO: Conforme a documentación aportada por HM HOSPITALES en fecha 14 de septiembre de 2023, se considera acreditado que la deficiencia que presentaba su sistema de gestión de historias clínicas relativa a la trazabilidad de la actividad de intentos de login en el sistema y de usuarios que han accedido, la actividad de acceso a los diferentes módulos, incluyendo a qué historia clínica se ha accedido, así como el tipo de información o parte de la historia clínica que se ha consultado, ha sido subsanada tras constatarse en la evaluación de impacto realizada en marzo del 2023.

DUODÉCIMO: Consta en el expediente, en las alegaciones al acuerdo de inicio presentadas por HM HOSPITALES en fecha 14 de septiembre de 2023, la siguiente afirmación relativa a la limitación realizada en su última revisión respecto al número de

usuarios que pueden acceder al sistema de gestión “*Doctoris*” “... el número de usuarios con permisos de crear, modificar perfiles, de forma que en la actualidad solamente hay 12 usuarios que pueden administrar, modificar y crear perfiles en *Doctoris* con el objetivo de tener un control más reforzado sobre la creación y asignación de perfiles...”.

DECIMOTERCERO: Consta en el expediente, en las alegaciones al acuerdo de inicio presentadas por HM HOSPITALES en fecha 14 de septiembre de 2023, acreditado documentalmente que este ha procedido a programar un mecanismo que permite bloquear los datos de salud en “*Doctoris*”, para impedir su tratamiento, incluyendo su visualización, cuando proceda.

Dicho mecanismo establece un plazo de tiempo y una vez superado se procederá al borrado automático de los datos bloqueados.

DECIMOCUARTO: Consta en el expediente que HM HOSPITALES disponía de un cifrado automático en los sistemas de almacenamiento de disco y que actualmente se ha finalizado el proceso de implantación del cifrado de las bases de datos en reposo utilizando tecnología TDE de SQL Server.

DECIMOQUINTO: Consta en el expediente, Plan Semestral de Auditorías de fecha 27 de mayo de 2023, PLAN SEMESTRAL DE AUDITORÍAS, en el que se dice textualmente: “

“...se reconoció la necesidad de llevar a cabo una auditoría en los centros ubicados en Málaga que se incorporaron al grupo en el año 2022, con el fin de verificar la adopción de los procesos establecidos por la Organización, en particular, aquellos relacionados con el Sistema de Gestión de Privacidad (SGP) de los centros de Desarrollos Asistenciales Sur, S.L.

Los centros hospitalarios implicados en esta auditoría son:

- Hospital HM Málaga.
- Hospital HM Gálvez.
- HM Santa Elena.
- HM El Pilar.

El propósito principal de esta auditoría es asegurar que los centros hospitalarios mantengan el alto nivel de cumplimiento exigido desde HM Hospitales aplicando las políticas y procedimientos internos establecidos para garantizar la privacidad y seguridad de la información de los pacientes y del personal médico. A través de una revisión exhaustiva, se busca identificar incumplimientos y áreas de mejora en la gestión de la privacidad de los datos de carácter personal en estos centros...” (el subrayado es de esta AEPD).

FUNDAMENTOS DE DERECHO

I

Competencia

De acuerdo con los poderes que el artículo 58.2 del RGPD, otorga a cada autoridad de control y según lo establecido en los artículos 47, 48.1, 64.2 y 68.1 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los

derechos digitales (en adelante, LOPDGDD), es competente para iniciar y resolver este procedimiento la Directora de la Agencia Española de Protección de Datos.

Asimismo, el artículo 63.2 de la LOPDGDD determina que: *"Los procedimientos tramitados por la Agencia Española de Protección de Datos se registrarán por lo dispuesto en el Reglamento (UE) 2016/679, en la presente ley orgánica, por las disposiciones reglamentarias dictadas en su desarrollo y, en cuanto no las contradigan, con carácter subsidiario, por las normas generales sobre los procedimientos administrativos."*

II Obligación incumplida

En el artículo 4 del RGPD, puntos 7 y 8, se especifica lo que se debe entender por responsable del tratamiento y encargado del tratamiento. Así tenemos, como:

“7) «responsable del tratamiento» o «responsable» es la persona física o jurídica, autoridad pública, servicio u otro organismo que, solo o junto con otros, determine los fines y medios del tratamiento; si el Derecho de la Unión o de los Estados miembros determina los fines y medios del tratamiento, el responsable del tratamiento o los criterios específicos para su nombramiento podrá establecerlos el Derecho de la Unión o de los Estados miembros;

8) «encargado del tratamiento» o «encargado» es la persona física o jurídica, autoridad pública, servicio u otro organismo que trate datos personales por cuenta del responsable del tratamiento...”.

En el presente caso, HM realiza esta actividad en su condición de responsable del tratamiento, dado que es quien determina los fines y medios de tal actividad, en virtud del citado artículo 4.7 del RGPD.

Si bien, TRC realiza esta actividad en su condición de encargado del tratamiento, dado que trata datos personales por cuenta del responsable del tratamiento, de conformidad con el citado artículo 4.8 del RGPD.

En definitiva, el responsable del tratamiento es la persona física o jurídica o autoridad pública, que decide sobre el tratamiento de los datos personales, determinando los fines y los medios de dicho tratamiento.

En virtud del principio de responsabilidad proactiva el responsable del tratamiento tiene que aplicar medidas técnicas y organizativas de seguridad para, en atención al riesgo que implica el tratamiento de los datos personales, cumplir y ser capaz de demostrar el cumplimiento.

Por su parte, el encargado del tratamiento es la persona física o jurídica, autoridad pública, servicio u otro organismo que presta un servicio al responsable que conlleva el tratamiento de datos personales por cuenta de éste.

En este sentido, el responsable es quien decide el “por qué” y el “cómo” relativo a los datos personales y el encargado es quien se encarga de llevar a cabo el tratamiento a cargo del responsable.

La figura del encargado del tratamiento en el RGPD se define en su artículo 28, donde se establecen los requisitos que debe cumplir respecto a la protección de datos:

1. Cuando se vaya a realizar un tratamiento por cuenta de un responsable del tratamiento, este elegirá únicamente un encargado que ofrezca garantías suficientes para aplicar medidas técnicas y organizativas apropiadas, de manera que el tratamiento sea conforme con los requisitos del presente Reglamento y garantice la protección de los derechos del interesado.

2. El encargado del tratamiento no recurrirá a otro encargado sin la autorización previa por escrito, específica o general, del responsable. En este último caso, el encargado informará al responsable de cualquier cambio previsto en la incorporación o sustitución de otros encargados, dando así al responsable la oportunidad de oponerse a dichos cambios.

3. El tratamiento por el encargado se regirá por un contrato u otro acto jurídico con arreglo al Derecho de la Unión o de los Estados miembros, que vincule al encargado respecto del responsable y establezca el objeto, la duración, la naturaleza y la finalidad del tratamiento, el tipo de datos personales y categorías de interesados, y las obligaciones y derechos del responsable. Dicho contrato o acto jurídico estipulará, en particular, que el encargado:

a) tratará los datos personales únicamente siguiendo instrucciones documentadas del responsable, inclusive con respecto a las transferencias de datos personales a un tercer país o una organización internacional, salvo que esté obligado a ello en virtud del Derecho de la Unión o de los Estados miembros que se aplique al encargado; en tal caso, el encargado informará al responsable de esa exigencia legal previa al tratamiento, salvo que tal Derecho lo prohíba por razones importantes de interés público;

b) garantizará que las personas autorizadas para tratar datos personales se hayan comprometido a respetar la confidencialidad o estén sujetas a una obligación de confidencialidad de naturaleza estatutaria;

c) tomará todas las medidas necesarias de conformidad con el artículo 32(...).

4. Cuando un encargado del tratamiento recurra a otro encargado para llevar a cabo determinadas actividades de tratamiento por cuenta del responsable, se impondrán a este otro encargado, mediante contrato u otro acto jurídico establecido con arreglo al Derecho de la Unión o de los Estados miembros, las mismas obligaciones de protección de datos que las estipuladas en el contrato u otro acto jurídico entre el responsable y el encargado a que se refiere el apartado 3, en particular la prestación de garantías suficientes de aplicación de medidas técnicas y organizativas apropiadas de manera que el tratamiento sea conforme con las disposiciones del presente Reglamento. Si ese otro encargado incumple sus obligaciones de protección de datos, el encargado inicial seguirá siendo plenamente responsable ante el responsable del tratamiento por lo que respecta al cumplimiento de las obligaciones del otro encargado. (...).

Estas obligaciones específicas podrán ser supervisadas por las autoridades de protección de datos, sin perjuicio de la fiscalización que pueda realizarse en relación con el cumplimiento del RGPD o de la LOPDGDD por parte del responsable o el encargado del tratamiento.

III

Alegaciones a la propuesta de resolución

En respuesta a las alegaciones presentadas por HM se debe señalar, según el orden expuesto, lo siguiente:

ALEGACIONES

HM indica:

Primera. En cuanto al cifrado de datos.

En la propuesta de resolución, esta Agencia señala que " En contestación a lo alegado, esta Agencia debe significar que en el momento en el que se iniciaron las actuaciones de investigación, así como en el momento en el que se inició el presente procedimiento sancionador HM disponía del nivel mínimo de cifrado, correspondiente al sistema operativo y a la base de datos". Aunque entendemos la preocupación, creemos necesario volver a indicar que el instructor da a entender que HM Hospitales considera que el cifrado en cabina no es suficiente y por eso planificamos el cifrado por software DES de SQL. Deseamos subrayar varios aspectos cruciales que demuestran nuestro profundo compromiso con la seguridad de los datos:

- 1. Suficiencia del Cifrado por Hardware: Contrario a lo sugerido, el cifrado por hardware implementado en nuestra cabina de discos proporcionaba seguridad equivalente al cifrado DES de SQL. La única limitación detectada fue que la capacidad de la base de datos estaba restringida al espacio disponible en la cabina, una limitación que no compromete la efectividad del cifrado en sí.*
- 2. Implementación del Cifrado TDE de SQL: La transición al cifrado por software TDE de SQL fue una medida proactiva para eliminar las restricciones de tamaño de la base de datos y no una respuesta a una deficiencia de seguridad. Este cambio refleja la política de HM HOSPITALES mejora continua en las prácticas de seguridad.*

En HM HOSPITALES, la prestación de asistencia sanitaria es nuestra actividad principal. Mientras que la seguridad de los datos es crucial, es igualmente importante garantizar la disponibilidad de estos datos para la atención continua de los pacientes. A continuación, detallamos cómo hemos manejado este equilibrio:

- 1. Atender a nuestros pacientes: Nuestro proceso de implementación del nuevo cifrado se ha planificado con el objetivo de asegurar que la atención a los pacientes no se vea interrumpida. Esto ha implicado en ocasiones posponer las actualizaciones de cifrado para mantener la accesibilidad continua de los datos clínicos necesarios para la atención.*

2. Inclusión de Nuevos Centros: La expansión de nuestra red con la adición de seis nuevos hospitales trajo consigo desafíos significativos en términos de integración de datos y gestión de la infraestructura tecnológica. A pesar de estos desafíos, nos aseguramos de que las medidas de cifrado se implementaran sin comprometer la integridad o la seguridad de los datos.

3. Equilibrio entre seguridad y accesibilidad: Entendemos que el acceso rápido y seguro a los datos médicos es vital para una atención efectiva. Por ello, nuestras soluciones de cifrado están diseñadas para garantizar tanto la protección de los datos como su accesibilidad inmediata cuando los profesionales sanitarios lo requieren.

Este enfoque demuestra nuestra dedicación a proporcionar una atención médica de alta calidad, garantizando que las medidas de seguridad de datos apoyen nuestra misión principal y no obstaculicen la atención al paciente.

Por último, queremos volver a resaltar que el cifrado previamente utilizado por HM HOSPITALES ya proporcionaba un nivel de seguridad que superaba el mínimo indicado por la AEPD:

1. Alta Seguridad: Utilizábamos estándares de cifrado avanzados como AES-128 y AES-256, garantizando que los datos estuvieran protegidos contra accesos no autorizados. Estos métodos de cifrado son extremadamente robustos y ampliamente reconocidos por su eficacia.

2. Cifrado a Nivel de Firmware: Al cifrar datos a nivel de firmware (por LUN), asegurábamos que la protección de datos se aplicara a toda la unidad lógica, proporcionando una capa adicional de seguridad directamente integrada en el hardware.

3. Unidades de Autocifrado (SED): Las unidades de autocifrado que utilizaban cifrado de hardware en lugar de firmware ofrecían ventajas significativas, como:

3.1. Rendimiento: No había pérdida de rendimiento ya que el cifrado no cargaba el sistema. Esto era crucial en entornos que requieren alta disponibilidad y rendimiento constante.

3.2. Seguridad Mejorada: El cifrado a nivel de hardware es menos susceptible a ciertos tipos de ataques que podrían afectar a soluciones basadas en software o firmware.

3.3. Cumplimiento Normativo: El uso de estos niveles de cifrado ayudaba a HM HOSPITALES a cumplir con diversas regulaciones de protección de datos y seguridad de la información.

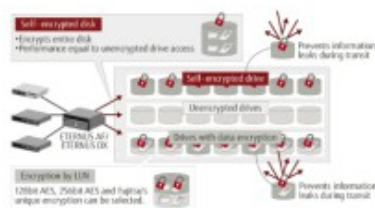
Se aporta como enlace la información facilitada por el fabricante de la cabina sobre la seguridad del sistema de cifrado utilizado para mayor clarificación: <https://www.fujitsu.com/global/products/computing/storage/disk/eternusdx/features/strsys-d11.html>

Information security by Data Encryption

Following legislation, including personal information protection laws, America's Sarbanes Oxley act and Japan's Financial Instruments and Exchange Law, the security of enterprise information has gained greater significance. Good corporate social responsibility requires that access to stored data is restricted to authorized users and any unauthorized or accidental access to sensitive information is blocked.

ETERNUS AF/ETERNUS DX use high levels of encryption to prevent unauthorized data access. This includes firmware encryption (by LUN) as standard, world-standard 128bit AES (Advanced Encryption Standard) technology, 256bit AES¹ and the support of Fujitsu's unique encryption with high-process performance.

ETERNUS also supports Self Encrypting Drives (SED). Here the disk drive uses hardware encryption instead of firmware. This enables data encryption without performance loss as no load is placed on the system by firmware operation.



Required authentication keys are provided for the key management group in which SED are registered. Authentication keys generated and stored by a key management server are provided for a required device as necessary. Secure uniform management can achieve authentication key management and reduce risk of important data leakage. The auto generation/rotation functions of authentication keys and backup function of those key information achieve authentication key lifecycle management and reduce operations management costs.

Product Requirements

Self encrypting disk storage	All-Flash Arrays	ETERNUS AF250 S3/S2, AF250 ETERNUS AF650 S3/S2, AF650
	Hybrid Storage Systems	ETERNUS DX100 S5/S4/S3, DX200 S5/S4/S3 ETERNUS DX500 S5/S4/S3, DX600 S5/S4/S3 ETERNUS DX900 S5 ETERNUS DX8700 S3/S2, DX8900 S4/S3 ETERNUS DX80 S2, DX90 S2 ETERNUS DX400 S2 series
Encryption by firmware	All-Flash Arrays	ETERNUS AF150 S3 ETERNUS AF250 S3/S2, AF250 ETERNUS AF650 S3/S2, AF650 ETERNUS DX200F
	Hybrid Storage Systems	ETERNUS DX100 S5/S4/S3, DX200 S5/S4/S3 ETERNUS DX500 S5/S4/S3, DX600 S5/S4/S3 ETERNUS DX900 S5 ETERNUS DX8700 S3/S2, DX8900 S4/S3 ETERNUS DX60 S2 ² , DX80 S2, DX90 S2 ETERNUS DX400 S2 series

Se acompaña igualmente como ANEXO I documento adicional informativo sobre las características técnicas que garantiza el proveedor Fujitsu así como certificado de nuestro proveedor TRC INFORMATICA relativo al cifrado de datos.

En contestación a lo alegado, esta Agencia Española de Protección de datos debe insistir en el hecho de que el sistema de base de datos SQL Server que disponía HM tiene su propio sistema de cifrado, un nivel mínimo de cifrado para el tratamiento de datos personales.

Dicho nivel mínimo cifrado suponía que, en el supuesto de pérdida de control física del sistema habría dificultad de acceso; sin embargo, en el supuesto de acceso indebido al sistema no existiría barrera que impidiera el acceso a los datos y documentos.

Este sistema de cifrado vino a reforzar y completar el sistema de cifrado configurado por defecto en el propio servidor del sistema.

Y así lo reconoce la propia entidad reclamada en su escrito de alegaciones de fecha 14 de septiembre de 2023, en el que manifiesta expresamente:

“En el momento de las alegaciones se encontraba en período de implantación –a fecha de hoy ya implantado- el sistema TDE, que viene a mejorar el que ya existía en ese momento, el sistema de cifrado realizado por el “Controller Module” de la cabina de almacenamiento. HM HOSPITALES únicamente trasladó información en sus 11 anteriores escritos sobre el proceso de mejora del software de Hosma a Doctoris, y el nuevo y adicional proceso de cifrado que se estaba llevando a cabo con el objetivo de implantar el cifrado con tecnología TDE de SQL Server en el sistema de información de historias clínicas.

El modelo de la cabina de almacenamiento utilizada por el sistema de información de historias clínicas DX200 S4 dispone y disponía de un cifrado automático en los sistemas de almacenamiento de disco mediante la tecnología AES de 128 bits o Fujitsu Original Encryption, garantizando que los datos estén protegidos cuando se usan y durante las transferencias de datos a instalaciones de archivado a otra ubicación...” (El subrayado es de este organismo).

Es evidente que si se viene a mejorar el que ya existía es porque el sistema de cifrado implantado era insuficiente; y todo ello, a pesar de que la tipología de los datos objeto de tratamiento exigía el mejor sistema de cifrado existente y el más adecuado al riesgo del tratamiento de dichos datos a gran escala y categorías especiales de datos personales, entre otras cuestiones, no pudiendo serlo, como se ha acreditado, con un sistema establecido por defecto en el propio servidor del sistema. Su insuficiencia en relación a los riesgos es lo que determina la comisión de la infracción y la imposición de la sanción.

En consecuencia, es evidente la falta de un sistema de cifrado de datos personales acorde a los posibles riesgos estimados.

Tal y como se ha hecho constar en el hecho probado sexto HM HOSPITALES ha venido celebrando contratos con el sector público para la prestación de asistencia sanitaria, desde el año 2022:

Por tanto, desde ese momento HM HOSPITALES está obligada al cumplimiento del Esquema Nacional de Seguridad, de conformidad con lo previsto en el artículo 2 del

Real Decreto 311/2022, de 3 de mayo, por el que se regula el Esquema Nacional de Seguridad, que establece:

“Artículo 2. Ámbito de aplicación.

1. El presente real decreto es de aplicación a todo el sector público, en los términos en que este se define por el artículo 2 de la Ley 40/2015, de 1 de octubre, y de acuerdo con lo previsto en el artículo 156.2 de la misma.

2. Asimismo, sin perjuicio de la aplicación de la Ley 9/1968, de 5 de abril, de Secretos Oficiales y otra normativa especial, este real decreto será de aplicación a los sistemas que tratan información clasificada, pudiendo resultar necesario adoptar medidas complementarias de seguridad, específicas para dichos sistemas, derivadas de los compromisos internacionales contraídos por España o de su pertenencia a organismos o foros internacionales.

3. Este real decreto también se aplica a los sistemas de información de las entidades del sector privado, incluida la obligación de contar con la política de seguridad a que se refiere el artículo 12, cuando, de acuerdo con la normativa aplicable y en virtud de una relación contractual, presten servicios o provean soluciones a las entidades del sector público para el ejercicio por estas de sus competencias y potestades administrativas”.

Asimismo, debemos insistir en lo preceptuado en la DA 1ª de la LOPDGDD, que establece:

“Disposición adicional primera. Medidas de seguridad en el ámbito del sector público.

1. El Esquema Nacional de Seguridad incluirá las medidas que deban implantarse en caso de tratamiento de datos personales para evitar su pérdida, alteración o acceso no autorizado, adaptando los criterios de determinación del riesgo en el tratamiento de los datos a lo establecido en el artículo 32 del Reglamento (UE) 2016/679.

2. Los responsables enumerados en el artículo 77.1 de esta ley orgánica deberán aplicar a los tratamientos de datos personales las medidas de seguridad que correspondan de las previstas en el Esquema Nacional de Seguridad, así como impulsar un grado de implementación de medidas equivalentes en las empresas o fundaciones vinculadas a los mismos sujetas al Derecho privado.

En los casos en los que un tercero preste un servicio en régimen de concesión, encomienda de gestión o contrato, las medidas de seguridad se corresponderán con las de la Administración pública de origen y se ajustarán al Esquema Nacional de Seguridad.”.

Por otro lado, tampoco debe olvidarse lo dispuesto en el artículo 3 del ya citado Real Decreto 311/2022, que dispone expresamente que:

“Artículo 3. Sistemas de información que traten datos personales.

1. Cuando un sistema de información trate datos personales le será de aplicación lo dispuesto en el Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo, de 27 de abril de 2016, relativo a la protección de las personas físicas en lo que respecta

al tratamiento de datos personales y a la libre circulación de estos datos y por el que se deroga la Directiva 95/46/CE (Reglamento General de Protección de Datos) y en la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales, o, en su caso, la Ley Orgánica 7/2021, de 26 de mayo, de protección de datos personales tratados para fines de prevención, detección, investigación y enjuiciamiento de infracciones penales y de ejecución de sanciones penales, el resto de normativa de aplicación, así como los criterios que se establezcan por la Agencia Española de Protección de Datos o en su ámbito competencial, por las autoridades autonómicas de protección de datos, sin perjuicio de los requisitos establecidos en el presente real decreto.”

En relación con el cifrado, el Esquema Nacional de Seguridad establece:

5.7.3 Cifrado de la información [mp.info.3].

Para el cifrado de información se estará a lo que se indica a continuación:

dimensiones C	nivel bajo	medio	alto
	no aplica	no aplica	aplica

a) La información con un nivel alto en confidencialidad se cifrará tanto durante su almacenamiento como durante su transmisión. Sólo estará en claro mientras se está haciendo uso de ella.

[...]

En consecuencia, el cifrado se debe aplicar a:

- La dimensión de confidencialidad,
- Los datos en el nivel alto, y
- Los datos almacenados (en reposo).

Hacer uso de un cifrado correcto implica lo siguiente:

- Que el sistema de cifrado que se emplee no esté comprometido, es decir, que en el momento de utilizarlo no se conozca forma alguna de romperlo.
- Que se disponga de un sistema de gestión de claves adecuado y robusto, así como de un procedimiento de administración de material criptográfico, en general.

A la hora de seleccionar un método de cifrado, aparte de tener en cuenta los dos puntos anteriores, se deberá tener en cuenta que las opciones disponibles cuentan con distintas características, por lo que será necesario analizar y elegir el sistema de cifrado que más se adecúe al servicio en el que se quiere integrar, es decir, si se va a utilizar para el envío de información a un tercero, si se requiere de cifrado en reposo...etc.

Dicho lo anterior, debemos insistir en que el sistema de base de datos SQL Server que disponía HM tenía su propio sistema de cifrado, un nivel mínimo de cifrado para el tratamiento de datos personales.

En consecuencia, HM no se preocupó de valorar y evaluar si dicho sistema de cifrado era o no suficiente para garantizar un nivel de seguridad adecuado al riesgo.

Dicho nivel mínimo cifrado suponía que, en el supuesto de pérdida de control física del sistema habría dificultad de acceso; sin embargo, en el supuesto de acceso indebido al sistema no existiría barrera que impidiera el acceso a los datos y documentos.

Este sistema de cifrado vino a reforzar y completar el sistema de cifrado configurado por defecto en el propio servidor del sistema.

En consecuencia, es evidente que HM no disponía de sistema robusto de cifrado para garantizar un nivel de seguridad adecuado al riesgo en el tratamiento de los datos personales.

HM continúa diciendo que

Segunda. Auditorías.

Esta parte quiere hacer las siguientes consideraciones sobre los siguientes comentarios realizados por esta Agencia: “No se ha acreditado la realización de auditorías en el sistema de información DOCTORIS (ni en sus versiones anteriores) para garantizar las medidas técnicas y organizativas de seguridad implantadas”.

En relación con los comentarios realizados por esta Agencia respecto a la falta de acreditación de auditorías en el sistema de información DOCTORIS (y sus versiones anteriores) para garantizar las medidas técnicas y organizativas de seguridad implantadas, esta Parte quiere hacer las siguientes consideraciones:

Es posible que haya existido cierto malentendido a lo largo del Procedimiento, imputable en todo caso nuestra Parte, pues todo lo contrario a la afirmación planteada por este Organismo, HM HOSPITALES tiene diversos cauces para acreditar la revisión continua de su Sistema de Gestión de Privacidad.

En anteriores alegaciones, se aportó acreditación documental de la revisión por parte del Departamento DPO de las nuevas adquisiciones por parte del grupo hospitalario, en este caso, los centros hospitalarios de Málaga. Esta revisión se materializa en auditorías denominadas de cumplimiento normativo, donde se realiza un primer diagnóstico de cumplimiento (CUMPLE/NO CUMPLE/NO APLICA) tomando en consideración el Reglamento (UE) 2016/679, del Parlamento Europeo y del Consejo, de 27 de abril de 2016, relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos (Reglamento General de Protección de Datos) y la Ley Orgánica 3/2018, de 5 de diciembre, de Protección

de Datos Personales y garantía de los derechos digitales.

Estas auditorías quedan planificadas principalmente cuando se produce alguna modificación estructural en una determinada sociedad (transformación, absorción, fusión, transmisión, ...) o se traspasa un negocio o actividad, o si cesa

en la actividad. En este sentido, dada la expansión del grupo hospitalario, quedaron planificadas la elaboración de este tipo de auditorías en la red de hospitales de la provincia de Málaga, tal y como ha quedado acreditado en anteriores alegaciones.

Distintas a estas auditorías, HM HOSPITALES revisa desde el diseño o como consecuencia del cumplimiento del artículo 24.1. del RGPD “Dichas medidas se revisarán y actualizarán cuando sea necesario” tal y como hemos expuesto en anteriores alegaciones y que entendemos que para mayor claridad debemos aportar en estas:

1. Informe de Auditoría externalizada de Cumplimiento del Procedimiento de Homologación de Sistema de Receta Médica Privada Electrónica.

Con motivo de la certificación de los sistemas de prescripción y repositorios de prescripciones del sistema de receta electrónica privada se realizó una auditoría exhaustiva sobre el software DOCTORIS certificando su cumplimiento con los estándares requeridos para la operación segura y confiable dentro del ámbito de la receta médica privada electrónica.

Aportamos como Anexo Nº II el informe completo en el que se demuestra la rigurosidad con la que se evalúa la seguridad y el cumplimiento del software objeto de sanción.

2. Informe de Auditoría de KPMG.

Anualmente, HM HOSPITALES es auditado de forma externalizada por la entidad KPMG, una firma de auditoría de renombre internacional. En estas auditorías se revisa el software DOCTORIS, entre otras cuestiones. Dada la naturaleza confidencial del contenido completo del informe, el acceso directo a toda la información del mismo no era posible; No obstante, para aclaración de este apartado consideramos proporcionar en el mismo Anexo Nº II los resultados del año 2023 de KPMG.

La presentación subraya que DOCTORIS cumple con criterios de seguridad específicos y confirma que las medidas de protección de datos están adecuadamente implementadas y son efectivas.

En contestación a lo alegado, esta Agencia únicamente recordó a HM que el artículo 32. del RGPD establece la necesidad de “verificación y evaluación” de las medidas técnicas implementadas por el responsable:

Teniendo en cuenta el estado de la técnica, los costes de aplicación, y la naturaleza, el alcance, el contexto y los fines del tratamiento, así como riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas, el responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, que en su caso incluya, entre otros:

(...) d) un proceso de verificación, evaluación y valoración regulares de la eficacia de las medidas técnicas y organizativas para garantizar la seguridad del tratamiento.

Por tanto, es evidente que se trata de un principio que establece para los responsables y encargados la obligación “proactiva” del cumplimiento de la norma y ello a través de la implantación de medidas técnicas y organizativas de seguridad que sean apropiadas. Dichas medidas además deben ser revisadas y actualizadas, periódicamente.

Es la propia entidad la que afirma que “... en los últimos tres años, no se ha hecho ninguna auditoría específica sobre el software...” justificando la ausencia de estas en el hecho de que DOCTORIS está en constante cambio/mejora, sin que esos cambios ni mejoras se hayan hecho constar.

Si bien, HM afirma, y así consta en el expediente, que “una vez superada la situación de emergencia sanitaria el Comité de Privacidad HM HOSPITALES aprobó en abril de 2023 la realización de auditorías en distintos centros para verificar el nivel de cumplimiento en relación con la normativa vigente de protección de todos los sistemas de información en el segundo semestre de este año...”.

Constatado el hecho de que Informe aportado por HM en periodo probatorio corresponde al Informe de Resultados de la Auditoría llevada a cabo únicamente en los centros ubicados en Málaga, como consecuencia de su incorporación al grupo en el año 2022, sorprende que, en este momento del procedimiento HM aporte; a pesar de lo afirmado, un informe de fecha enero de 2021, en el que consta, expresamente:

2. Objeto

El objeto de este documento es comprobar el cumplimiento de los requerimientos relacionados con el proceso de auditoría de certificación de los Sistemas de Prescripción y Repositorios de Prescripciones para operar en el Sistema de Receta Electrónica Privada por parte de HM Hospitales.

3. Alcance

El alcance de esta auditoría recae sobre los sistema de receta electrónica del grupo de HM hospitales cuyos sistemas se encuentran ubicados en el Hospital HM Madrid ubicado en la Plaza del Conde del Valle de Súchil, 2 y el grupo TRC ubicado en la Calle Albasanz, 25, ambas localizaciones sitas en Madrid, siendo este último el establecido como proveedor principal para el desempeño del funcionamiento del sistema de receta electrónica.

Por tanto, se deja constancia que dicha auditoría, únicamente, tiene por objeto el Sistema de Receta Electrónica Privada utilizada por parte de HM Hospitales y no “DOCTORIS” como software de gestión hospitalaria utilizado por HM HOSPITALES 1989, S.A.

Si bien, en el informe de diciembre de 2023 de KPMG presentado y al que hace referencia la entidad reclamada en sus alegaciones se hace referencia brevemente a las áreas de mejora IT respecto al software “DOCTORIS”.

Es de resaltar y conviene dejar constancia de ello en esta resolución, que dicho informe contiene expresamente:

Áreas de mejora IT

Evolución con
respecto a 2022

Área de mejora



Gestión de Cambios → DOCTORIS

Observación ejercicio 2022: Si bien el Grupo contaba con un repositorio donde se mantiene el registro de toda la gestión de cambios correspondiente al sistema Doctoris, la aplicación no contaba con un log de subidas a producción que permitan mantener la trazabilidad de los cambios realizados en la aplicación, lo que generaría la imposibilidad de identificar cambios no autorizados en el entorno productivo de la aplicación.

Se recomendaba implementar un log de modificaciones de la aplicación Doctoris o un mecanismo que permitiese dejar evidencias de las subidas a producción realizadas. Asimismo, se recomendaba incluir en sus procedimientos que todos los cambios sean aprobados por el área del negocio solicitante.

Observación ejercicio 2023: No ha sido posible obtener el log técnico (directamente desde el servidor productivo) de cuáles ha sido las versiones que han estado operativas en el año. Para llevar el seguimiento de las versiones operativas, el Grupo cuenta con un registro manual desde herramienta de ticketing para interactuar con el proveedor TRC (SGCOL) en la que incluyen las versiones que se ponen en funcionamiento en el entorno productivo junto con los cambios en las funcionalidades que engloba cada versión.

Fecha de implementación de mejora: Pendiente de definir.

Evidentemente, dicha auditoría no responde a un cumplimiento de la obligación que tiene el responsable del tratamiento de verificación, evaluación y valoración de la eficacia de las medidas técnicas y organizativas implantadas, en el presente caso, en el software de gestión hospitalaria utilizado por HM HOSPITALES 1989, S.A. "DOCTORIS" para garantizar la seguridad del tratamiento.

En relación a las áreas de mejoras de IT respecto al software "DOCTORIS" mencionar que, en todo caso, se refiere a mejoras en el entorno del software y no de mejoras del software con la finalidad de garantizar las medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo del tratamiento de datos personales llevado a cabo por el citado software.

HM continúa diciendo que:

Tercera. Garantía de cumplimiento del Encargado del Tratamiento.

En referencia a la elección del proveedor del sistema de gestión de Historia Clínica, TRC INFORMÁTICA, S.L., queremos informar que dicho proveedor cumple con lo estipulado en el artículo 28.1 del RGPD, que establece lo siguiente: "Cuando se vaya a realizar un tratamiento por cuenta de un responsable del tratamiento, este elegirá únicamente un encargado que ofrezca garantías suficientes para aplicar medidas técnicas y organizativas apropiadas, de manera que el tratamiento sea conforme con los requisitos del presente Reglamento y garantice la protección de los derechos del interesado".

En consonancia con esta afirmación, el artículo 28.5., del RGPD señala que La adhesión del encargado del tratamiento a un código de conducta aprobado a

tenor del artículo 40 o a un mecanismo de certificación aprobado a tenor del artículo 42 podrá utilizarse como elemento para demostrar la existencia de las garantías suficientes a que se refieren los apartados 1 y 4 del presente artículo”.

Así pues, TRC INFORMATICA, S.L., aporta como ANEXO N.º III las certificaciones que en la actualidad tiene concedidas y que evidencian no solo el compromiso y cumplimiento normativo por parte del proveedor TRC INFORMATICA, S.L., sino también la diligencia de HM HOSPITALES a la hora de seleccionar al Encargado del tratamiento, asegurando que todas las medidas técnicas y organizativas apropiadas están implementadas para garantizar la protección de los derechos de los interesados.

Se aporta al Anexo referenciado los siguientes Certificados:

- *Certificado por OCA-Instituto de Certificación, SLU del sistema de gestión medioambiental de TRC conforme la norma UNE-EN ISO 14001:2015.*
- *Certificado por OCA-Instituto de Certificación, SLU del sistema de gestión de servicios de T.I. conforme la norma ISO/IEC 20000-1:2018.*
- *Certificado por OCA-Instituto de Certificación, SLU del sistema de gestión de la seguridad de la información de TRC conforme la norma UNE-ISO/IEC 27001:2017.*
- *Certificado por OCA-Instituto de Certificación, SLU del sistema de seguridad y salud laboral de TRC conforme la norma UNE-EN ISO 45001:2018.*
- *Certificado por OCA-Instituto de Certificación, SLU del sistema de gestión de la calidad de TRC conforme la norma UNE-EN ISO 9001:2015.*
- *Certificado por OCA-Instituto de Certificación, SLU de madurez del software de TRC conforme la norma ISO/IEC 15504.*
- *Certificado por OCA-Instituto de Certificación, SLU de tecnología de la información de TRC conforme la norma ISO/IEC 33001:2015.*
- *Certificado por IMQ IBÉRICA de conformidad con el Esquema Nacional de Seguridad nivel Alto.*
- *Certificado por OCA-Instituto de Certificación, SLU de conformidad con el Esquema Nacional de Seguridad nivel Medio. Renovada por nivel Alto.*

En contestación a lo alegado, debemos mencionar que esta Agencia Española de Protección de Datos en ningún momento, ha puesto en duda la diligencia de HM HOSPITALES a la hora de seleccionar al Encargado del tratamiento ni el compromiso ni el cumplimiento normativo por parte del proveedor y encargado del tratamiento TRC INFORMATICA, S.L.

Si bien, esta Agencia Española de Protección de Datos celebra las certificaciones que tiene concedidas TRC INFORMATICA, S.L.

La entidad alega que:

Cuarta. De la demostración durante el procedimiento del cumplimiento del artículo 32 del Reglamento General de Protección de Datos.

HM HOSPITALES ha mostrado un compromiso firme con el cumplimiento de las medidas de seguridad y protección de los datos de carácter personal, mantenimiento y mejorando las medidas ya implementadas.

La AEPD fundamenta la investigación y establece una propuesta de sanción inicial de 200.000 euros por el incumplimiento de varios puntos de control, cuyo grado de cumplimiento (en todo, o en parte) se ha demostrado con la documentación aportada en los distintos escritos de alegaciones a la AEPD como se detalla a continuación:

I. Sobre la falta de medidas para garantizar la confidencialidad de los datos, este Organismo debería validar que el cifrado previamente utilizado por HM HOSPITALES proporcionaba un nivel de seguridad que superaba el mínimo indicado por la AEPD (cifrado por hardware implementado en nuestra cabina de discos proporcionaba seguridad equivalente al cifrado DES de SQL.), y que se ha mejorado con la implantación de un sistema de cifrado utilizando tecnología TDE de SQL Server.

En contestación a lo alegado, este organismo debe insistir en el hecho de que si HM ha mejorado el sistema de cifrado es porque dicho sistema era insuficiente e inadecuado al nivel de riesgo en el tratamiento de datos, tal y como está probado.

II. Sobre el posible uso de bases de datos reales utilizadas para pruebas en sistemas de preproducción y desarrollo, se demostró y quedó suficientemente acreditado que se utilizan datos ficticios en entornos de prueba.

En contestación a este punto, debemos hacer constar que nada se ha alegado por esta Agencia Española en relación al uso de bases de datos reales para pruebas en sistemas de preproducción y desarrollo. No obstante, celebramos que se utilicen datos ficticios en entornos de prueba.

III. En relación con la posible inexistencia de trazabilidad de los accesos al sistema de gestión hospitalaria por parte de los usuarios que consultan las historias clínicas, se aportó y se da por reproducido documento elaborado por TRC que demuestra con pantallazos del programa DOCTORIS la trazabilidad de los usuarios que acceden a los datos de las historias clínicas de pacientes.

En contestación a lo alegado en relación a la trazabilidad, esta Agencia Española de Protección de Datos ya apuntó en la propuesta de resolución que celebraba que por parte de HM HOSPITALES se hubieran subsanado las deficiencias detectadas a lo largo de la tramitación del presente procedimiento sancionador en relación a la trazabilidad.

Si bien es cierto, tal y como consta en el hecho probado décimo, en el Informe de cumplimiento normativo que acompaña al Informe de Evaluación de Impacto relativa a la Protección de Datos HM HOSPITALES 1989, S.A., de fecha de realización el 15 de marzo de 2023 y bajo la responsabilidad de Don , delegado de protección de datos, consta literalmente:

Medidas de protección de datos	
Acceso a documentos	Se detecta que los perfiles no están bien implantados (enfermería, investigadores).
Acceso a equipos y redes informáticas	Se accede mediante usuario y contraseña personalizados
Acceso a categorías especiales de datos	Existen medidas adicionales de seguridad (llaves, restricción de acceso, seudonimización, cifrado, etc.) Se detecta que DOCTORIS permite trazabilidad de accesos y de modificaciones, pero no permite conocer quien consulta los datos de HCE.
Seguridad de la contraseña	Se aplican medidas de seguridad (cifrado, combinación de caracteres, cambio periódico, etc.)

Por otro lado, la subsanación de dichas deficiencias dejaba clara la insuficiencia y debilidad de las medidas técnicas y organizativas de seguridad implantadas para garantizar la trazabilidad de los accesos a los datos personales por parte de los usuarios autorizados, y, por tanto, la comisión de la infracción.

En este sentido, se hizo constar la sentencia de la AN de 9 de febrero de 2023 (rec. 770/2022) que dice:

“(…) Las medidas de seguridad implementadas con posterioridad, no afectan a la comisión de la infracción y contrariamente a lo pretendido por la actora no pueden amparar la aplicación de una eximente, sin perjuicio de que hayan sido tomada en consideración como atenuante del artículo 83.2.c) del RGPD a la hora de fijar la sanción”.

IV. En referencia a la realización de auditorías sobre cualquiera de las versiones de DOCTORIS, se aporta informe completo de la auditoría realizada con motivo de la certificación de la receta electrónica, y el informe elaborado por la empresa KPMG.

En contestación a lo alegado, en relación a la realización de auditorías, este organismo debe subrayar que el informe elaborado por la empresa KPMG, únicamente, tiene por objeto el Sistema de Receta Electrónica Privada utilizada por parte de HM Hospitales y no “DOCTORIS” como software de gestión hospitalaria utilizado por HM HOSPITALES 1989, S.A.

V. Respecto de los perfiles de usuario, informar a este Organismo nuestro fuerte compromiso en la mejora constante de aspecto, teniendo en consideración, además, que somos un grupo hospitalario que está en constante expansión. Queremos recordar a esta Agencia que en la Auditoría de KPMG aportada como observación Durante el ejercicio 2023 se ha podido observar que el Grupo ha reducido el número de perfiles (existían más de 400 y ahora existen unos 50). De igual forma hay que señalar que se ha creado una Comisión de revisión de perfiles y permisos en la que se han estado analizando, reduciendo y homogeneizando los permisos asignados en DOCTORIS. Esta comisión se mantendrá para tomar decisiones sobre nuevos accesos que se salgan del circuito habitual de asignación de perfiles definidos. Este seguimiento únicamente debiera ser valorado como actitud diligente y proactiva y no negligente.

En contestación a lo alegado, esta Agencia Española de Protección de datos se congratula de las medidas adoptadas con la finalidad de evitar perfiles y permisos mal implantados; si bien, debemos insistir en lo expuesto en la sentencia de la AN de 9 de febrero de 2023 (rec. 770/2022) que dice:

“(...) Las medidas de seguridad implementadas con posterioridad, no afectan a la comisión de la infracción (...)”.

Por último y antes de pasar a contestar a las demás alegaciones, esta Agencia debe significar la asunción de responsabilidad por parte de HM en relación con el error en la implantación de los perfiles, así como en la ausencia de un sistema de supresión y bloqueo automático.

HM continúa diciendo que:

En respuesta a la interpretación de la jurisprudencia del Tribunal Supremo proporcionada por la AEPD “El Tribunal Supremo (Sentencias de 16 y 22 de abril de 1991) considera que del elemento culpabilista se desprende “...que la acción u omisión, calificada de infracción sancionable administrativamente, ha de ser, en todo caso, imputable a su autor, por dolo o imprudencia, negligencia o ignorancia inexcusable”. El mismo Tribunal razona que “no basta... para la exculpación frente a un comportamiento típicamente antijurídico la invocación de la ausencia de culpa” sino que es preciso “que se ha empleado la diligencia que era exigible por quien aduce su inexistencia” (STS 23 de enero de 1998)”.

HM HOSPITALES desea subrayar que las medidas de mejora en los sistemas de seguridad implementadas no son consecuencia de este procedimiento sancionador. Estas mejoras ya estaban identificadas y programadas como parte de nuestro plan de mejora continua antes del inicio del procedimiento, demostrando un compromiso proactivo y constante con la seguridad de los datos. Destacando la diligencia de HM HOSPITALES, como se evidencia en los procesos de certificación bajo el Esquema Nacional de Seguridad y la ISO 27001, reconocidos en alegaciones previas. Estos procesos de certificación son prueba de que se ha empleado la diligencia exigible para garantizar la seguridad y la protección de los datos personales de nuestros pacientes.

Además, en HM HOSPITALES como ya se ha indicado previamente, la disponibilidad de los datos para la asistencia sanitaria es una prioridad que se gestiona sin comprometer la seguridad. Las medidas implementadas aseguran tanto la protección de los datos como su accesibilidad, permitiendo la prestación de un servicio de calidad a los pacientes.

En conclusión, los cumplimientos antes expuestos tendrían que llevar aparejado una disminución o graduación en la cuantía de la sanción al quedar demostrado que HM HOSPITALES ha actuado con la diligencia debida, anticipando y abordando proactivamente las necesidades de seguridad en un marco de mejora continua y no como respuesta a acciones legales o administrativas.

En primer lugar y antes de contestar a lo alegado, no se puede estar más de acuerdo en que no cabe sanción económica si no hay concurrencia de intencionalidad o negligencia en la infracción.

A tal efecto, se hace necesario referirnos a la invocada Sentencia del Tribunal de Justicia de la Unión Europea, de 5 de diciembre de 2023, recaída en el asunto C-807/21 (Deutsche Wohnen), que indica:

“76 A este respecto, debe precisarse además, por lo que atañe a la cuestión de si una infracción se ha cometido de forma intencionada o negligente y, por ello, puede sancionarse con una multa administrativa con arreglo al artículo 83 del RGPD, que un responsable del tratamiento puede ser sancionado por un comportamiento comprendido en el ámbito de aplicación del RGPD cuando no podía ignorar el carácter infractor de su conducta, tuviera o no conciencia de infringir las disposiciones del RGPD (véanse, por analogía, las sentencias de 18 de junio de 2013, Schenker & Co. y otros, C 681/11, EU:C:2013:404, apartado 37 y jurisprudencia citada; de 25 de marzo de 2021, Lundbeck/Comisión, C 591/16 P, EU:C:2021:243, apartado 156, y de 25 de marzo de 2021, Arrow Group y Arrow Generics/Comisión, C 601/16 P, EU:C:2021:244, apartado 97).” (el subrayado es nuestro).

En la misma línea se expresan los órganos jurisdiccionales de nuestro país. Así, la Sentencia de la Audiencia Nacional, de 21 de enero de 2010, expone:

“La recurrente también mantiene que no concurre culpabilidad alguna en su actuación. Es cierto que el principio de culpabilidad impide la admisión en el derecho administrativo sancionador de la responsabilidad objetiva, también es cierto, que la ausencia de intencionalidad resulta secundaria ya que este tipo de infracciones normalmente se cometen por una actuación culposa o negligente, lo que es suficiente para integrar el elemento subjetivo de la culpa. La actuación de XXX es claramente negligente pues... debe conocer... las obligaciones que impone la LOPD a todos aquellos que manejan datos personales de terceros. XXX viene obligada a garantizar el derecho fundamental a la protección de datos personales de sus clientes e hipotéticos clientes con la intensidad que requiere el contenido del propio derecho”.

Además, el Tribunal Supremo (Sentencias de 16 y 22 de abril de 1991) considera que del elemento culpabilista se desprende “...que la acción u omisión, calificada de infracción sancionable administrativamente, ha de ser, en todo caso, imputable a su autor, por dolo o imprudencia, negligencia o ignorancia inexcusable”. El mismo Tribunal razona que “no basta... para la exculpación frente a un comportamiento típicamente antijurídico la invocación de la ausencia de culpa” sino que es preciso “que se ha empleado la diligencia que era exigible por quien aduce su inexistencia” (STS 23 de enero de 1998).

Conectada también con el grado de diligencia que el responsable del tratamiento está obligado a desplegar en el cumplimiento de las obligaciones que le impone la normativa de protección de datos puede citarse la Sentencia de la Audiencia Nacional de 17 de octubre de 2007 (Rec. 63/2006), que precisó: “(...) el Tribunal Supremo viene entendiendo que existe imprudencia siempre que se desatiende un deber legal de cuidado, es decir, cuando el infractor no se comporta con la diligencia exigible”.

A mayor abundamiento, la Audiencia Nacional en materia de protección de datos de carácter personal, ha declarado que *“basta la simple negligencia o incumplimiento de los deberes que la Ley impone a las personas responsables de ficheros o del tratamiento de datos de extremar la diligencia...”* (Sentencia de la Audiencia Nacional de 29 de junio de 2001).

En consecuencia, es evidente que en el presente caso hay negligencia por esa falta de diligencia en el cumplimiento de la normativa vigente en materia de protección de datos, no procediendo, por dicha causa, una disminución o graduación en la cuantía de la sanción.

HM continúa diciendo que:

Quinta. Del principio de proporcionalidad en la imposición de sanciones.

El principio de proporcionalidad, tal como se establece en el artículo 29 de la Ley 40/2015 de Régimen del Sector Público, es fundamental en la imposición de sanciones por las Administraciones Públicas. Este principio indica que:

- *29.2: El establecimiento de sanciones pecuniarias debe prever que la comisión de las infracciones tipificadas no resulte más beneficiosa para el infractor que el cumplimiento de las normas infringidas.*
- *29.3: La determinación del régimen sancionador y la imposición de sanciones deben observar la idoneidad y necesidad de la sanción a imponer, adecuándola a la gravedad de la infracción. La graduación de la sanción debe considerar especialmente los siguientes criterios:*
 - *Grado de culpabilidad o intencionalidad: Evaluar si hubo una intención deliberada de infringir la normativa.*
 - *Continuidad o persistencia en la conducta infractora: Determinar si la conducta infractora ha sido continua o persistente.*
 - *Naturaleza de los perjuicios causados: Considerar los daños o perjuicios causados por la infracción.*
 - *Reincidencia: Tener en cuenta si ha habido reincidencia por la comisión de más de una infracción de la misma naturaleza en el término de un año, declarada por resolución firme en vía administrativa.*

En el presente caso, HM HOSPITALES ha demostrado la inexistencia de una intención deliberada de infringir la normativa (artículo 32 del Reglamento General de Protección de Datos) y la inexistencia de “Continuidad o persistencia en la conducta infractora”, hechos que se pueden demostrar con los cumplimientos detallados, y la implementación adicional de mecanismos y refuerzos en las medidas de seguridad ya existentes para garantizar una mayor protección de los datos personales, que aunado a su diligencia y buena fe, debería ser un factor determinante en la evaluación de la proporcionalidad de la sanción.

Asimismo, en relación con la “Naturaleza de los perjuicios causados” no ha existido reclamación o afectación de los derechos fundamentales de los usuarios, tampoco hemos tenido brechas o incidentes de seguridad que

afecten o pongan en peligro los datos, ni se ha causado ningún daño o perjuicios por la infracción.

En cuanto a la “reincidencia” es primera vez que se produce un incumplimiento en el ámbito objeto de denuncia (medidas de seguridad en DOCTORIS), y no existe, ni aplica el agravante de reincidencia en este tipo de conducta, haciendo necesario reconsiderar la severidad de cualquier sanción impuesta bajo estos principios.

En contestación a lo alegado, debe señalarse, en primer lugar, que el artículo 29 de la Ley 40/2015 de Régimen del Sector Público (en adelante, LRJSP) no resulta de aplicación al régimen sancionador impuesto por el RGPD, en atención a que el propio RGPD tiene su propio régimen de proporcionalidad en el artículo 83 del RGPD.

En relación, específicamente, con el régimen sancionador dispuesto en el RGPD, resultan de aplicación sus disposiciones de manera inmediata, directa e íntegra previendo un sistema completo que ha de entenderse, interpretarse e integrarse de forma completa, íntegra, dejando así indemne su finalidad última que es la garantía efectiva y real del derecho fundamental a la Protección de Datos de Carácter Personal.

Así, en cuanto a la imposición de multas en los términos del art. 83 del RGPD, estas han de ser efectivas, proporcionadas y disuasorias para la consecución de la finalidad pretendida por el RGPD.

Para que dicho sistema funcione con todas sus garantías es necesario que varios elementos se desplieguen de forma íntegra y completa. La aplicación de reglas ajenas al RGPD respecto de la determinación de las multas en cada uno de los Estados miembros aplicando su derecho nacional, ya sea por circunstancias agravantes o atenuantes no previstas en el RGPD -o en la LOPDGDD en el caso español-, restaría efectividad al sistema que perdería su sentido, su finalidad teleológica, resultando que las multas impuestas por distintas infracciones dejarían de ser efectivas, proporcionadas y disuasorias. Y de esta forma también se hurtaría a los interesados de la garantía efectiva de sus derechos y libertades, debilitando la aplicación uniforme del RGPD. Se disminuirían los mecanismos de protección de los derechos y las libertades de los ciudadanos y sería contrario con el espíritu del RGPD.

El RGPD está dotado de su propio principio de proporcionalidad que ha de ser aplicado en sus estrictos términos, resultando que no hay laguna legal alguna que determine la aplicabilidad del art. 29 de la Ley 40/2015.

Asimismo, se ha de indicar que el art. 63.2 LOPDGDD consagra no ya el carácter supletorio (que serviría para colmar lagunas, que no existen, como hemos visto) sino el carácter subsidiario (que no supletorio) de la normativa general de los procedimientos administrativos respecto de las normas que rigen los procedimientos de la AEPD en materia de protección de datos.

Dice así el art. 63.2 LOPDGDD:

“2. Los procedimientos tramitados por la Agencia Española de Protección de Datos se regirán por lo dispuesto en el Reglamento (UE) 2016/679, en la presente ley orgánica, por las disposiciones reglamentarias dictadas en su desarrollo y, en cuanto no las

contradigan, con carácter subsidiario, por las normas generales sobre los procedimientos administrativos...”.

El legislador español ha optado pues por el principio de subsidiariedad, que no de supletoriedad, de las normas generales de procedimiento administrativo frente a las específicas del RGPD y LOPDGDD. Dicha relación entre supletoriedad y subsidiariedad hay que entenderla, como ya lo ha hecho la Sala a la que nos dirigimos, en el sentido mencionado en la sentencia de la Audiencia Nacional de 23 de octubre de 2001 (Rec. 390/1999, ECLI:ES:AN:2001:6122), cuando recordaba que *“el recurso a la subsidiariedad es una fórmula de colaboración normativa para los casos de concurso de normas, esto es, para los casos en los que resulten aplicables dos o más de ellas al mismo supuesto de hecho, de manera que la subsidiaria cede en beneficio de la primaria a la que, en su caso, complementa”*, a diferencia de la supletoriedad, que tiene por objeto colmar una laguna *“de tal manera que cuando un determinado supuesto no es objeto de regulación por la norma inicialmente aplicable se da paso a la supletoria, siempre, eso sí, que semejante operación no resulte, por otras circunstancias, disconforme al ordenamiento jurídico”*.

En el presente caso, la norma primaria sería el RGPD, que regula expresamente en su art. 83 el principio de proporcionalidad, no siendo de aplicación la regulación del art. 29 de la ley 40/2015 precisamente por su carácter subsidiario.

En segundo lugar, se ha de poner de manifiesto que el artículo 83.4 del RGPD dispone:

“Las infracciones de las disposiciones siguientes se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 10 000 000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 2 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

a) las obligaciones del responsable y del encargado a tenor de los artículos 8, 11, 25 a 39, 42 y 43; (...)”

Por tanto, una multa de:

- 200.000 euros, en el caso de la infracción del artículo 32 del RGPD,

Se encuentran en el tramo inferior de las sanciones posibles, dando así cumplimiento al artículo 83.1 del RGPD anteriormente citado: *“Cada autoridad de control garantizará que la imposición de las multas administrativas con arreglo al presente artículo por las infracciones del presente Reglamento indicadas en los apartados 4, 5 y 6 sean en cada caso individual, efectivas, proporcionadas y disuasorias.”*

Si bien, este Organismo debe dejar constancia que, en la graduación de la sanción y dada la especialidad de la materia, se han tenido en cuenta los siguientes criterios por imperativo del artículo 83.2 del RGPD y del apartado 2 del artículo 76 “Sanciones y medidas correctivas” de la LOPDGDD:

Como agravantes:

- *b) la intencionalidad o negligencia en la infracción;*
- Insistimos en este sentido, en lo ya argumentado respecto a la intencionalidad o negligencia en la infracción.

Como agravantes:

- *b) La vinculación de la actividad del infractor con la realización de tratamientos de datos personales.*

Es evidente la vinculación de la actividad empresarial y el tratamiento de los datos personales de los pacientes, significando, además que, dicho tratamiento se realizaba a gran escala, tal y como consta en el hecho probado quinto.

IV

Artículo 32 del RGPD

El Artículo 32 “*Seguridad del tratamiento*” del RGPD establece:

“1. Teniendo en cuenta el estado de la técnica, los costes de aplicación, y la naturaleza, el alcance, el contexto y los fines del tratamiento, así como riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas, el responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, que en su caso incluya, entre otros:

- a) la seudonimización y el cifrado de datos personales;*
- b) la capacidad de garantizar la confidencialidad, integridad, disponibilidad y resiliencia permanentes de los sistemas y servicios de tratamiento;*
- c) la capacidad de restaurar la disponibilidad y el acceso a los datos personales de forma rápida en caso de incidente físico o técnico;*
- d) un proceso de verificación, evaluación y valoración regulares de la eficacia de las medidas técnicas y organizativas para garantizar la seguridad del tratamiento.*

2. Al evaluar la adecuación del nivel de seguridad se tendrán particularmente en cuenta los riesgos que presente el tratamiento de datos, en particular como consecuencia de la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos.

3. La adhesión a un código de conducta aprobado a tenor del artículo 40 o a un mecanismo de certificación aprobado a tenor del artículo 42 podrá servir de elemento para demostrar el cumplimiento de los requisitos establecidos en el apartado 1 del presente artículo.

4. El responsable y el encargado del tratamiento tomarán medidas para garantizar que cualquier persona que actúe bajo la autoridad del responsable o del encargado y tenga acceso a datos personales solo pueda tratar dichos datos siguiendo

instrucciones del responsable, salvo que esté obligada a ello en virtud del Derecho de la Unión o de los Estados miembros”.

En el presente caso, consta que HM, no disponía de las medidas de seguridad razonables en función de los posibles riesgos estimados.

Respecto a la adecuación de las medidas implantadas a las exigidas para sistemas con tratamientos de datos de salud e historias clínicas:

Se ha constatado que el sistema DOCTORIS (y sus versiones anteriores) Sí realiza trazabilidad de qué usuarios han accedido al sistema de información y de si estos accesos han sido correctos o fallidos, también se registra trazabilidad sobre qué módulos del sistema ha visitado cada usuario (opciones de menú utilizadas), no obstante, se han acreditado las siguientes deficiencias:

(...).

Existen informes internos del responsable HM sobre cumplimiento normativo de estas actividades que incluyen las siguientes conclusiones:

(...).

No se ha acreditado la realización de auditorías en el sistema de información DOCTORIS (ni en sus versiones anteriores) para garantizar las medidas técnicas y organizativas de seguridad implantadas.

HM afirma que *“En relación con la realización de auditorías sobre cualquiera de las versiones de Doctoris en los últimos tres años esta parte informa que no ha tenido lugar ninguna”*. Esta carencia contrasta con la siguiente afirmación realizada en el Registro de Actividades de tratamiento en el apartado referente a las medidas de seguridad de la actividad HCE:

Realización de auditorías sobre las medidas técnicas y organizativas de seguridad implantadas para verificar su correcto funcionamiento.

En relación con la garantía de la confidencialidad en los tratamientos, ha quedado constatado que (...).

No obstante, en relación con las medidas para garantizar la supresión o bloqueo de los datos: (...).

Por lo expuesto, se considera que los hechos conocidos son constitutivos de una infracción, imputable a HM, por vulneración del artículo 32 del RGPD.

V

Tipificación de la infracción del artículo 32 del RGPD

La citada infracción del artículo 32 del RGPD supone la comisión de la infracción tipificada en el artículo 83.4 a) del RGPD que bajo la rúbrica *“Condiciones generales para la imposición de multas administrativas”* dispone:

“Las infracciones de las disposiciones siguientes se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 10 000 000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 2 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

a) las obligaciones del responsable y del encargado a tenor de los artículos 8, 11, 25 a 39, 42 y 43; (...)”

A este respecto, la LOPDGDD, en su artículo 71 “Infracciones” establece que *“Constituyen infracciones los actos y conductas a las que se refieren los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679, así como las que resulten contrarias a la presente ley orgánica”.*

A efectos del plazo de prescripción, el artículo 73 “Infracciones consideradas graves” de la LOPDGDD indica:

“En función de lo que establece el artículo 83.4 del Reglamento (UE) 2016/679 se consideran graves y prescribirán a los dos años las infracciones que supongan una vulneración sustancial de los artículos mencionados en aquel y, en particular, las siguientes:

(...)

f) La falta de adopción de aquellas medidas técnicas y organizativas que resulten apropiadas para garantizar un nivel de seguridad adecuado al riesgo del tratamiento, en los términos exigidos por el artículo 32.1 del Reglamento (UE) 2016/679.

VI

Sanción por la infracción del artículo 32 del RGPD

A efectos de decidir sobre la imposición de una multa administrativa y su cuantía, procede graduar la sanción a imponer de acuerdo con los siguientes criterios que establece el artículo 83.2 del RGPD:

Como agravantes:

- *b) la intencionalidad o negligencia en la infracción;*

En este mismo sentido, el Tribunal Supremo viene entendiendo que existe imprudencia siempre que se desatiende un deber legal de cuidado, es decir, cuando el infractor no se comporta con la diligencia exigible. Y en la valoración del grado de diligencia ha de ponderarse especialmente la profesionalidad o no del sujeto, y no cabe duda de que, en el caso ahora examinado, cuando la actividad de la recurrente es de constante y abundante manejo de datos de carácter personal ha de insistirse en el rigor y el exquisito cuidado por ajustarse a las prevenciones legales al respecto. **[Sentencia de la Audiencia Nacional de 17/10/2007 (rec. 63/2006)]**

Asimismo, se considera que procede graduar la sanción a imponer de acuerdo con los siguientes criterios que establece el apartado 2 del artículo 76 “Sanciones y medidas correctivas” de la LOPDGDD:

Como agravantes:

- b) La vinculación de la actividad del infractor con la realización de tratamientos de datos personales.

HM ofrece servicios sanitarios para el cuidado y bienestar de nuestros pacientes y sus familiares mediante una oferta asistencial completa, con el compromiso de aportar valor a clientes, accionistas, empleados y al conjunto de la sociedad.

Su actividad principal es la gestión de servicios sanitarios asistenciales, docentes y de investigación para el mantenimiento y mejora de la salud de la población, lo que requiere un conocimiento y tratamiento continuo de datos personales de categorías especiales de datos de sus pacientes y usuarios.

Dicho tratamiento, tal y como consta en el Informe de análisis de necesidad de Evaluación de Impacto de Datos Personales, aportado HM HOSPITALES en fecha 14 de septiembre de 2023, es a gran escala.

El balance de las circunstancias contempladas en el artículo 83.2 del RGPD y el artículo 76.2 de la LOPDGDD, con respecto a la infracción cometida al vulnerar lo establecido en el artículo 32 del RGPD, permite fijar inicialmente una sanción de 200.000 € (DOSCIENTOS MIL EUROS).

Por lo tanto, de acuerdo con la legislación aplicable y valorados los criterios de graduación de las sanciones cuya existencia ha quedado acreditada,

la Directora de la Agencia Española de Protección de Datos RESUELVE:

PRIMERO: IMPONER a HM HOSPITALES 1989, S.A., con NIF A79325858, por una infracción del Artículo 32 del RGPD, tipificada en el Artículo 83.4 del RGPD, una multa de 200.000,00 euros (DOSCIENTOS MIL euros).

SEGUNDO: NOTIFICAR la presente resolución a HM HOSPITALES 1989, S.A.

TERCERO: Esta resolución será ejecutiva una vez finalice el plazo para interponer el recurso potestativo de reposición (un mes a contar desde el día siguiente a la notificación de esta resolución) sin que el interesado haya hecho uso de esta facultad. Se advierte al sancionado que deberá hacer efectiva la sanción impuesta una vez que la presente resolución sea ejecutiva, de conformidad con lo dispuesto en el art. 98.1.b) de la ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en adelante LPACAP), en el plazo de pago voluntario establecido en el art. 68 del Reglamento General de Recaudación, aprobado por Real Decreto 939/2005, de 29 de julio, en relación con el art. 62 de la Ley 58/2003, de 17 de diciembre, mediante su ingreso, indicando el NIF del sancionado y el número de procedimiento que figura en el encabezamiento de este documento, en la cuenta restringida nº **IBAN: ES00 0000 0000 0000 0000 0000 (BIC/Código SWIFT:**

XXXXXXXXXXXXX), abierta a nombre de la Agencia Española de Protección de Datos en la entidad bancaria CAIXABANK, S.A.. En caso contrario, se procederá a su recaudación en período ejecutivo.

Recibida la notificación y una vez ejecutiva, si la fecha de ejecutividad se encuentra entre los días 1 y 15 de cada mes, ambos inclusive, el plazo para efectuar el pago voluntario será hasta el día 20 del mes siguiente o inmediato hábil posterior, y si se encuentra entre los días 16 y último de cada mes, ambos inclusive, el plazo del pago será hasta el 5 del segundo mes siguiente o inmediato hábil posterior.

De conformidad con lo establecido en el artículo 50 de la LOPDGDD, la presente Resolución se hará pública una vez haya sido notificada a los interesados.

Contra esta resolución, que pone fin a la vía administrativa conforme al art. 48.6 de la LOPDGDD, y de acuerdo con lo establecido en el artículo 123 de la LPACAP, los interesados podrán interponer, potestativamente, recurso de reposición ante la Directora de la Agencia Española de Protección de Datos en el plazo de un mes a contar desde el día siguiente a la notificación de esta resolución o directamente recurso contencioso administrativo ante la Sala de lo Contencioso-administrativo de la Audiencia Nacional, con arreglo a lo dispuesto en el artículo 25 y en el apartado 5 de la disposición adicional cuarta de la Ley 29/1998, de 13 de julio, reguladora de la Jurisdicción Contencioso-administrativa, en el plazo de dos meses a contar desde el día siguiente a la notificación de este acto, según lo previsto en el artículo 46.1 de la referida Ley.

Finalmente, se señala que conforme a lo previsto en el art. 90.3 a) de la LPACAP, se podrá suspender cautelarmente la resolución firme en vía administrativa si el interesado manifiesta su intención de interponer recurso contencioso-administrativo. De ser éste el caso, el interesado deberá comunicar formalmente este hecho mediante escrito dirigido a la Agencia Española de Protección de Datos, presentándolo a través del Registro Electrónico de la Agencia [<https://sedeagpd.gob.es/sede-electronica-web/>], o a través de alguno de los restantes registros previstos en el art. 16.4 de la citada Ley 39/2015, de 1 de octubre. También deberá trasladar a la Agencia la documentación que acredite la interposición efectiva del recurso contencioso-administrativo. Si la Agencia no tuviese conocimiento de la interposición del recurso contencioso-administrativo en el plazo de dos meses desde el día siguiente a la notificación de la presente resolución, daría por finalizada la suspensión cautelar.

938-16012024

Mar España Martí
Directora de la Agencia Española de Protección de Datos